# CRISC Revision Guide: All Domains & Topics

Prepared by Mamudu (Mo) Kankasa · LinkedIn: linkedin.com/in/mkankasa

October 2026 · *Independent study notes. Not affiliated with or endorsed by ISACA. CRISC is a registered trademark of ISACA.*

## Exam snapshot and golden rules

The exam is 150 single-best-answer questions in 4 hours, about 96 seconds each, scored 200–800 with 450 to pass. Every topic below uses the same brief: where it sits, what you need to know, most-tested angles and traps, when it happens, and a memory hook.

| Domain | Weight | Topics |
|---|---|---|
| 1 Governance | 26% | 7 |
| 2 Risk Assessment | 22% | 9 |
| 3 Risk Response & Reporting | 32% | 7 |
| 4 Technology & Security | 20% | 8 |

**The seven golden rules**

1. **Business objectives first.** Every answer traces back to strategy and risk appetite.
2. **The owner decides; the practitioner advises.** The practitioner analyses, recommends, facilitates and monitors. They never accept, approve, implement or take ownership.
3. **Assess before you treat.** FIRST questions favour understanding: assess, find the root cause, confirm with the owner.
4. **Governance before tools.** Policy, ownership and process come before technology.
5. **Preventive over detective.** Fix the process, not the alarm. Use existing capability before buying new.
6. **Evidence over paperwork.** Behaviour and outcomes beat activity metrics; proof beats promises.
7. **Proportionate, not absolute.** Distrust “all”, “always”, “ban”, “terminate”, and board escalation for routine issues.

**How to use this guide:** read one domain’s briefs, then do that domain’s exam-level practice set before moving on.

# Domain 1: Governance (26%)

Governance sets the direction everything else serves: objectives, roles, culture, rules and appetite. The topics run in this order: 1.1 Strategy → 1.2 Roles → 1.3 Culture → 1.4 Policies and processes → 1.5 Frameworks and three lines → 1.6 Appetite and profile → 1.7 Legal and ethics.

## 1.1 Organisational strategy, goals and objectives

**Where it sits:** the starting point of the whole risk cycle. Every later step measures risk against these objectives.

**What you need to know**

- Risk is the effect of uncertainty on objectives. Without objectives, risk can't be rated.
- IT risk management exists to protect and enable business strategy, not IT for its own sake.
- Goals cascade: enterprise goals → IT alignment goals → processes and controls.
- The practitioner must understand strategy before defining risk management strategy.

| Trap | What the exam rewards |
|---|---|
| Start from threats or technology | Start from business objectives |
| IT strategy set on its own | IT strategy aligned to business strategy |
| No strategic planning = obsolete systems risk | Greatest risk is poor oversight of IT investment |

**When it happens:** before any risk identification or appetite setting. *Example: before building the risk strategy for a digital bank, the practitioner reviews the plan to grow online lending by 40%.*

**Hook:** *"No destination, no wrong turn: objectives make risk measurable."*

**Exam focus:** know that objectives come first for any programme, strategy or enterprise-wide assessment; IT risk is aligned through business impact; risk governance aims at value creation. Not needed: strategy planning models.

**Question tricks:** "FIRST" with an asset inventory or regulation list on offer (objectives win at enterprise scope); an option that repeats the stem ("align IT objectives"); a technical starting point that sounds practical.

**Key words:** objectives, strategy, goals cascade, alignment, value creation.

**Qualifier cues:** FIRST for a programme, strategy or enterprise-wide assessment → understand business objectives · MOST important when defining risk strategy → business objectives · PRIMARY objective of risk governance → value creation · BEST way to align IT risk → assess it by business impact.

**Terms to know**

- **Business objectives:** what the enterprise aims to achieve; the yardstick every risk is measured against.
- **Goals cascade:** enterprise goals → IT alignment goals → processes and controls (COBIT).
- **Strategic alignment:** IT plans and investments directly support business strategy.
- **Value creation:** realising benefits while optimising risk and resources; the ultimate aim of risk governance.
- **IT strategic plan:** how IT will support the business strategy; the first thing a new CIO creates.

## 1.2 Structure, roles and responsibilities

**Where it sits:** straight after strategy. It decides who owns, decides, executes and assures.

**What you need to know**

- **Board:** sets appetite, oversees the profile. **Senior management:** executes, approves major responses.
- **Risk owner:** accountable for risk-based decisions. **Control owner:** accountable for a control's design and operation, including routine monitoring.
- **Risk practitioner:** analyses, advises, facilitates, monitors. **Data owner** decides; **data custodian** (IT) implements.
- RACI: one Accountable per activity. Responsibility can be delegated; accountability cannot.
- The risk steering committee is the cross-functional forum to prioritise and escalate.

| Trap | What the exam rewards |
|---|---|
| Practitioner owns or accepts the risk | Owner decides; practitioner advises |
| IT owns business data or risk | Business owns; IT is custodian |
| Several people jointly accountable | One accountable person |
| Escalate unclear ownership to the CRO | Risk is owned where it arises; support the owner |

**When it happens:** when a risk enters the register. *Example: on adding supplier payment fraud, the finance director is named risk owner and the AP manager control owner of call-back verification.*

**Hook:** *"One owner decides, many hands help, the practitioner navigates."*

**Exam focus:** know who owns, decides, executes and assures; accountable vs responsible; IT structure types (centralised,

decentralised, federated); matching the stem's verb to the level. Not needed: org-chart design.

**Question tricks:** the specialist offered because the topic matches (DPO for privacy); the most senior role offered for "manage and execute"; options where the practitioner or audit takes ownership.

**Key words:** accountable, responsible, owner, custodian, steering committee, centralised, decentralised, federated.

**Qualifier cues:** MOST effective to manage and execute the programme → mid-level managers · who is ACCOUNTABLE → the business owner · BEST steering committee make-up → key members from each department · MOST likely to classify data → data owner.

**Terms to know**

- **Accountable:** answerable for the outcome; only ever one person.
- **Responsible:** does the work; can be several people.
- **RACI:** Responsible, Accountable, Consulted, Informed.
- **Risk owner:** has the authority and accountability for decisions about a risk.
- **Control owner:** accountable that a control is designed and operating; **control operator:** performs it.
- **Data owner:** decides classification, access and retention; **data custodian:** IT, which implements those decisions.
- **IT steering committee:** cross-functional group that prioritises and approves IT investment.
- **Centralised / decentralised / federated:** one body decides / each unit decides / central standards with local execution.
- **Segregation of duties (SoD):** splitting incompatible tasks (request, approve, record, hold assets) between different people.

**IT organisational structures**

- **Centralised:** one body (for example the IT steering committee) makes all IT decisions, including the budget. *Real life: a young company where leadership and one IT manager decide everything.*
- **Decentralised:** each business unit decides and funds its own IT. *Real life: acquired businesses keeping their own IT teams and budgets.*
- **Federated / hybrid:** central standards and governance, local execution. Often the balance large, multi-site enterprises choose. *Real life: group IT sets security policy; each site runs its own systems to it.*
- **Divisional:** IT organised by product, region or business unit.
- **Project-based:** IT organised around temporary projects.

**Exam cue:** find who makes the decisions and holds the budget. One place = centralised; many places = decentralised; one rulebook with local delivery = federated.

## 1.3 Organisational culture

**Where it sits:** underneath everything. It is how people actually behave with risk.

**What you need to know**

- Risk culture is the shared values and behaviours about risk.
- Tone at the top: visible senior management sponsorship makes risk a priority.
- Mature culture: open reporting of incidents and near misses without blame, owners managing their own risk.
- Measure culture by behaviour, not by policies or training completion.

| Trap | What the exam rewards |
|---|---|
| Board-approved policies prove culture | Behaviour proves culture |
| Discipline drives compliance | No-blame reporting surfaces risk early |
| Risk is the risk team's job | Everyone owns risk in their area |

**When it happens:** continuously; assessed in maturity reviews. *Example: a trader reports a mistaken order straight away and is thanked, not disciplined.*

**Hook:** *"A healthy culture hears bad news early; a sick one hears it from the regulator."*

**Exam focus:** know that culture shows in behaviour (open reporting, decisions within appetite), tone at the top, conflicts of interest and the ISACA Code duties. Not needed: culture survey methods.

**Question tricks:** "describes" culture (risk policy) vs "indicates" culture (behaviour); discipline offered as the fix; policies or training completion offered as proof of culture.

**Key words:** tone at the top, risk culture, ethics, conflict of interest, transparency, objectivity.

**Qualifier cues:** BEST indicator of culture → decisions aligned to appetite or open reporting · BEST describes culture → risk policy · GREATEST concern with blame → events go unreported · FIRST on a conflict of interest → identify and record it.

**Terms to know**

- **Risk culture:** the shared values and behaviours about risk across the enterprise.
- **Tone at the top:** leadership's visible commitment to managing risk.
- **Risk awareness:** staff understanding of the risks in their work.

- **No-blame reporting:** reporting errors and near misses without fear of punishment.
- **Conflict of interest:** a role or interest that could bias someone's judgement.
- **ISACA Code of Professional Ethics:** objectivity, due care, competence, confidentiality and honest reporting to the right parties.

## 1.4 Policies, standards, processes and assets

**Where it sits:** turns strategy and appetite into rules, applied to business processes and assets.

**What you need to know**

- Hierarchy: policy (intent, approved by senior management) → standards (mandatory specifics) → procedures (how-to).
- Policies align to appetite and are reviewed periodically and on significant change.
- Departures from policy go through the formal exception process.
- An asset inventory with owners, value and classification is the base for risk identification.
- Process mapping identifies the critical processes that risk work protects.

| Trap | What the exam rewards |
|---|---|
| IT writes and approves policy | Senior management approves; business-aligned |
| Policy left unreviewed | Reviewed periodically and on major change |
| Assets listed without owners | Every asset has an owner and a classification |
| Policy names specific products | Policy stays technology-neutral; standards get specific |

**When it happens:** after appetite is set, then reviewed annually. *Example: when the board raises appetite for cloud, the cloud policy is updated and a standard mandates encryption.*

**Hook:** *"Policy says what, standard says how much, procedure says how."*

**Exam focus:** know the document hierarchy, review triggers (schedule plus significant change), exceptions, asset inventory with owners, and one global policy amended for local law. Not needed: policy templates.

**Question tricks:** "no incidents" offered as a reason to skip a review; policies naming products; separate local policies that look more compliant.

**Key words:** policy, standard, procedure, guideline, baseline, exception, asset inventory.

**Qualifier cues:** FIRST after significant change → review the policy · PRIMARY purpose of a policy → management's direction · procedures SHOULD → be updated with each software release · BEST for a multinational → global policy amended for local law.

**Terms to know**

- **Policy:** management's high-level intent and the limits of acceptable behaviour.
- **Standard:** mandatory specific requirements that support a policy.
- **Procedure:** step-by-step instructions for a task or platform.
- **Guideline:** recommended, non-mandatory good practice.
- **Baseline:** the minimum security configuration for a platform.
- **Exception:** a temporary, approved departure from policy, with an expiry date.
- **Exemption:** a formally justified, longer-term exclusion from a requirement.
- **Asset inventory:** a list of assets, each with an owner, classification, value and location.
- **Business process mapping:** documenting how a process runs, to find critical steps and controls.

**The document hierarchy (this is the whole game)**

| Level | What it is | Mandatory? | Changes | Example |
|---|---|---|---|---|
| **Policy** | High-level statement of intent; says what and why; approved by the board or senior management | Yes | Rarely | "All personal data must be protected in accordance with applicable law." |
| **Standard** | Specific requirement supporting a policy; says the precise what; makes compliance measurable | Yes | Occasionally | "All personal data at rest must be encrypted using AES-256." |
| **Procedure** | Step-by-step how to do it; operational | Yes (for those who perform it) | Frequently, e.g. with each software release | "To encrypt a database, open the admin console, go to…" |
| **Guideline** | Recommended best practice | No | As needed | "Where feasible, also encrypt data in transit." |

**Exam cues:** "intent" or "limits of behaviour" → policy · "measurable requirement" or "baseline" → standard · "step-by-step" or "updated with each software release" → procedure · "recommended" or "non-mandatory" → guideline.

## 1.5 Risk frameworks, ERM and the three lines

**Where it sits:** the machinery that runs risk management across the enterprise.

**What you need to know**

- Frameworks: COBIT, ISO 31000, ISO 27005, NIST, COSO ERM. ISACA tests principles, not framework trivia.
- Tailor a framework to the enterprise's size, culture and objectives; never adopt it as-is.
- IT risk integrated into ERM uses the same language and scales, so enterprise decisions include it.
- **First line** owns and manages risk. **Second line** supports, challenges and monitors. **Third line** (internal audit) gives independent assurance.
- Second line never implements or accepts risk. Third line never owns risk or designs controls.

| Trap | What the exam rewards |
|---|---|
| ERM integration is about one tool or efficiency | It's about risk-informed enterprise decisions |
| Second line takes ownership "temporarily" | Second line supports the first line |
| Audit owns risk or designs controls | Audit stays independent |

**When it happens:** when the risk programme is built or matured. *Example: after a merger, IT risk is rated on the same 5×5 scale as financial risk.*

**Hook:** *"Players, referee, video replay: own, challenge, assure."*

**Exam focus:** know what each framework is for, tailoring, the purpose of ERM integration, and the three lines roles including which line does what. Not needed: clause numbers or framework versions.

**Question tricks:** the word "audit" in the stem points to the third line; second line "implementing" vs "developing"; one tool or efficiency offered as the PRIMARY purpose of integration.

**Key words:** ERM, framework, tailoring, three lines, assurance, independence, COBIT, ISO 31000.

**Qualifier cues:** PRIMARY benefit of ERM integration → risk-informed enterprise decisions · GREATEST risk to the three lines model → blurred roles · FIRST when establishing a framework → set accountabilities and responsibilities · MOST important when selecting a framework → fit with business objectives.

**Terms to know**

- **ERM (enterprise risk management):** managing all types of risk enterprise-wide against objectives.
- **Governance vs management (COBIT):** the board evaluates, directs and monitors; management plans, builds, runs and monitors.
- **First line:** business and operations; owns and manages risk.
- **Second line:** risk and compliance functions; develops the framework, supports, monitors and challenges.
- **Third line:** internal audit; gives independent assurance to the board.
- **Fourth line:** sometimes used for external assurance (external auditors, regulators).
- **Tailoring:** adapting a framework to the enterprise's size, objectives and risk.
- **Statement of Applicability (SoA):** ISO 27001's record of which controls apply, which don't, and why.
- **Assurance vs advisory:** audit gives independent assurance; it can advise but never decides or designs.

## 1.6 Risk profile, appetite and tolerance

**Where it sits:** the yardstick. Every assessed risk is compared against it.

**What you need to know**

- **Appetite:** the risk the enterprise will accept in pursuit of objectives. The board sets it from strategy and capacity.
- **Tolerance:** the acceptable variation around appetite, often a measurable threshold per objective.
- **Capacity:** the most loss the enterprise can absorb. Appetite sits inside capacity.
- **Risk profile:** the current overall exposure, reported against appetite.
- The practitioner assists stakeholders in setting appetite and reviews it when strategy changes.

| Trap | What the exam rewards |
|---|---|
| Base appetite on regulation or peers | Base it on strategy, capacity and the enterprise's culture and predisposition toward risk |
| Change appetite to fit a breach | Treat the risk or formally accept it |
| Appetite and tolerance are the same | Tolerance is the variation around appetite |
| Practitioner sets appetite | Board sets; practitioner assists |

**When it happens:** in strategic planning, then cascaded into KRI thresholds. *Example: the board sets zero tolerance for regulatory breach; KRI red thresholds follow.*

**Hook:** *"Capacity is the cliff edge, appetite is where you walk, tolerance is how far you may wobble."*

**Exam focus:** know capacity, appetite, tolerance and profile, who sets each, culture and predisposition as the key appetite

factor, and tolerance as a measurable deviation. Not needed: appetite statement wording.

**Question tricks:** a percentage of acceptable deviation (tolerance, not acceptance); moving a threshold to fit a breach; peers or regulation offered as the basis for appetite.

**Key words:** appetite, tolerance, capacity, profile, threshold, acceptable deviation.

**Qualifier cues:** MOST important when considering appetite → culture and predisposition toward risk · "acceptable % deviation" → tolerance · MOST significant benefit of a defined appetite → consistent risk-based decisions · who sets appetite → the board.

**Terms to know**

- **Risk capacity:** the most loss the enterprise can absorb without failing.
- **Risk appetite:** the amount of risk the enterprise is willing to accept in pursuit of its objectives.
- **Risk tolerance:** the acceptable variation around appetite, set as a measurable threshold.
- **Risk profile:** the enterprise's current overall exposure.
- **Threshold:** the KRI level (green, amber, red) that signals action.
- **Risk acceptance:** a decision to live with one specific risk; tolerance is the limit, acceptance is the decision.
- **Risk universe:** every potential risk the enterprise could face.

## 1.7 Legal, regulatory, contractual requirements and ethics

**Where it sits:** the boundaries around appetite, plus the practitioner's own conduct.

**What you need to know**

- Compliance requirements are a floor and an input to risk identification. Non-compliance is itself a risk scenario.
- Keep an obligations register with owners, and monitor regulatory change.
- Key contract clauses: right to audit, SLAs, breach notification, data protection.
- ISACA Code of Ethics: objectivity, due care, competence, confidentiality, honest reporting.
- Business-driven reasons outrank compliance-driven ones.

| Trap | What the exam rewards |
|---|---|
| Compliant = risk managed | Compliance is the minimum; manage risk beyond it |
| Soften a finding under pressure | Report objectively |
| Answer from a specific country's law | Answer from principles |

**When it happens:** during risk identification and on any regulatory change. *Example: a new data-protection law triggers an obligations-register update and a gap assessment.*

**Hook:** *"The law is the floor, not the ceiling."*

**Exam focus:** know compliance as the floor, how to respond to a new regulation, the most stringent baseline with legal counsel, common control mapping, and ethics duties. Not needed: specific laws (ISACA avoids country-specific law).

**Question tricks:** accepting non-compliance because the fine is smaller than the cost; "efficient" vs "complete" (mapping beats separate assessments); "only" the strictest regulation.

**Key words:** compliance, regulation, contractual, jurisdiction, legal counsel, control mapping, obligations register.

**Qualifier cues:** FIRST on a new regulation → assess applicability or gather compliance scenarios · BEST for efficient compliance → common control mapping · KEY objective of monitoring against external requirements → legal obligations satisfied · conflicting laws → most stringent baseline plus legal counsel.

**Terms to know**

- **Compliance risk:** the risk of penalties or loss from failing laws, regulations or contracts.
- **Contractual flow-down:** requirements a customer passes on to its suppliers.
- **Obligations register:** a list of applicable laws, regulations and contracts, each with an owner.
- **Data sovereignty:** data being subject to the laws of the country where it is stored.
- **Due diligence:** investigating before acting (for example before signing a supplier).
- **Due care:** acting responsibly and maintaining protection once committed.
- **Control mapping:** linking one control to every requirement it satisfies.
- **Most stringent baseline:** where requirements conflict, apply the strictest, with legal advice.

# Domain 2: Risk Assessment (22%)

Risk assessment finds, describes and rates risk, then compares it with appetite. The topics run in this order: 2.1 Identify → 2.2 Threats → 2.3 Vulnerabilities → 2.4 Scenarios → 2.5 Analysis methods → 2.6 BIA → 2.7 Inherent and residual → 2.8 Register → 2.9 Evaluate and prioritise.

## 2.1 Risk events and risk identification

**Where it sits:** the first step of assessment, once objectives and critical assets are known.

**What you need to know**

- Identify events that could affect objectives: internal and external, adverse and opportunity.
- Sources: owner workshops, interviews, audit findings, incident data, threat intelligence, emerging-risk scans.
- Combine top-down (from objectives) and bottom-up (from assets). ISACA starts top-down.
- Identification is continuous and repeated on change: new system, acquisition, regulation.

| Trap | What the exam rewards |
|---|---|
| IT identifies risk alone | Workshops with business owners |
| One annual exercise | Continuous, and on significant change |
| Incident history only | Forward-looking too: threats, emerging risk |

**When it happens:** at the start of each assessment and on any trigger. *Example: acquiring a subsidiary triggers identification workshops with its process owners.*

**Hook:** *"You can't treat what you haven't spotted, and the business spots most of it."*

**Exam focus:** know the sources of risk identification, top-down first, owner workshops, and that identification is continuous. Not needed: a catalogue of every technique.

**Question tricks:** a technical scan offered for a business-level risk profile; a one-off annual exercise; IT identifying risk alone.

**Key words:** risk event, identification, workshop, top-down, bottom-up, trigger.

**Qualifier cues:** BEST for an initial profile with little documentation → process-owner workshops · MOST likely trigger for reassessment → change in the business environment · PRIMARY reason to collect environment information → better risk decisions.

**Terms to know**

- **Risk event:** something that could happen and affect objectives.
- **Loss event:** an event that has actually caused a loss.
- **Near miss:** an event that almost caused a loss; free early warning.
- **Top-down identification:** starting from objectives and critical processes.
- **Bottom-up identification:** starting from assets, threats and generic risk lists.
- **Trigger event:** a change (acquisition, new system, regulation) that prompts a fresh assessment.
- **Emerging risk:** a new or developing risk that is not yet well understood.

## 2.2 Threat modelling and the threat landscape

**Where it sits:** inside identification. It asks who or what could cause harm.

**What you need to know**

- A threat is a potential cause of harm: criminals, insiders, nation states, errors, failures, natural events.
- The landscape shifts; monitor it through threat intelligence (feeds, ISACs, vendor reports).
- Threat modelling (for example STRIDE) analyses how a system could be attacked. Do it during design.
- Threat intelligence is an input, filtered for relevance to your assets, not the starting point.

| Trap | What the exam rewards |
|---|---|
| Start from threat feeds | Start from assets, then relevant threats |
| External attackers only | Insiders, errors and natural events too |
| Threat model after go-live | Threat model during design |

**When it happens:** during design (modelling) and continuously (landscape). *Example: designing a payment API, the team applies STRIDE and finds payment amounts could be tampered with.*

**Hook:** *"Know the burglars, but only after you know the house."*

**Exam focus:** know threat vs vulnerability, threat types (including non-human and external requirements), threat modelling at design, and threat analysis as the main input to incident response. Not needed: named threat actor groups.

**Question tricks:** a storm or a competitor offered to test whether you recognise a threat; threat feeds as the starting point; deferring threat modelling to late penetration testing.

**Key words:** threat, actor, threat landscape, threat intelligence, threat modelling, adversarial, accidental, environmental.

**Qualifier cues:** MOST valuable input to incident response → qualitative threat analysis · BEST time for threat modelling → design · MOST useful outcome of threat modelling → design changes.

**Terms to know**

- **Threat:** a potential cause of harm (an actor or an event).
- **Threat actor:** who or what causes it: criminals, insiders, nation states, nature, system failure.
- **Threat vector:** the route an attack uses (email, VPN, USB, supplier).
- **Attack surface:** all the points where an attacker could get in.
- **Threat landscape:** the current set of threats facing the sector or enterprise.
- **Threat intelligence:** information about threats, used to prioritise and prepare.
- **Threat modelling:** structured analysis of how a system could be attacked, done at design.
- **STRIDE:** Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege.
- **Threat sources (NIST 800-30):** adversarial, accidental, structural, environmental.

## 2.3 Vulnerability and control deficiency analysis

**Where it sits:** after threats. It asks which weakness they would exploit.

**What you need to know**

- A vulnerability is an exploitable weakness: technical, process, people or physical.
- Sources: scans, penetration tests (authorised and scoped), audits, control self-assessments, incidents.
- Prioritise by asset criticality × exposure, not by vendor CVSS score alone.
- A control deficiency is a control that is missing, badly designed or not operating. It raises residual risk.
- Close the loop: scan → assess → assign owner → remediate → verify.

| Trap | What the exam rewards |
|---|---|
| Prioritise by CVSS score | Prioritise by business criticality and exposure |
| Closed ticket = fixed | Verify remediation with a rescan |
| Deficiency fixed with an extra detective control | Fix the root cause; restore the preventive control |

**When it happens:** continuously (scanning) and in control assessments. *Example: one critical flaw on an internet-facing payments server outranks forty on isolated test servers.*

**Hook:** *“Same crack, different wall: fix the one holding up the roof.”*

**Exam focus:** know prioritisation by criticality × exposure; no patch → assess, then compensating controls; deficiency → the control owner fixes the root cause; verify remediation. Not needed: CVSS scoring mechanics.

**Question tricks:** CVSS offered as the basis for priority; a drastic “take it offline” first step; more frequent detective reviews offered as a root-cause fix.

**Key words:** vulnerability, CVSS, scan, penetration test, patch, deficiency, compensating control, exposure.

**Qualifier cues:** FIRST when no patch exists → assess exposure, then compensating controls · BEST basis for priority → criticality × exposure · MOST likely root cause of a deficiency → a gap in the preventive process.

**Terms to know**

- **Vulnerability:** a weakness a threat can exploit.
- **Exposure:** how open an asset is to a threat (for example internet-facing).
- **Zero-day:** a vulnerability with no patch available yet.
- **CVSS:** a technical severity score for a vulnerability; not business risk.
- **Vulnerability scan:** automated discovery of known weaknesses.
- **Penetration test:** an authorised, scoped attempt to exploit weaknesses.
- **Control deficiency:** a control that is missing, badly designed or not operating.
- **Compensating control:** an alternative control used when the primary one isn’t feasible.
- **False positive / false negative:** a reported issue that isn’t real / a real issue that wasn’t detected.

## 2.4 Risk scenario development

**Where it sits:** joins threat, vulnerability, asset and impact into one describable event.

**What you need to know**

- Scenario components: actor, threat type, event, asset or resource, and time.
- Start top-down from objectives and critical processes; use generic scenario libraries as a check.
- Scenarios must be realistic, relevant and validated with business owners.

- Review scenarios when the business, technology or threat landscape changes.

| Trap | What the exam rewards |
|---|---|
| Start from a generic scenario library | Start from objectives and critical processes |
| IT writes scenarios alone | Validated with business owners |
| Worst case only | Realistic, credible scenarios |

**When it happens:** after identification, before analysis. *Example: an AP clerk (actor) changes supplier bank details (event) in the ERP (asset) at month-end (time), diverting £500k.*

**Hook:** *"Who does what to which asset, when, and what it costs."*

**Exam focus:** know the components (actor, threat type, event, asset, time), top-down plus bottom-up, owner validation, historical data against bias, and risk factors as the first step. Not needed: scenario libraries by heart.

**Question tricks:** a generic library offered as best; worst cases offered for realism; an expert team vs historical data for addressing bias.

**Key words:** scenario, actor, event, asset, time, risk factor, bias, validation.

**Qualifier cues:** FIRST step in scenario development → identify risk factors · BEST approach → top-down plus bottom-up · BEST for realism → owner validation · BEST against bias → historical data.

**Terms to know**

- **Risk scenario:** a description of a possible event and its impact on objectives.
- **Scenario components:** actor, threat type, event, asset or resource, time.
- **Risk factor:** a condition that raises or lowers likelihood or impact (internal or external).
- **Generic scenario:** a standard library example, used as a checklist and then tailored.
- **Scenario validation:** confirming scenarios with business owners so they are realistic.
- **Bias:** distortion in judgement; reduced by using historical data.

## 2.5 Risk analysis methodologies

**Where it sits:** rates each scenario's likelihood and impact.

**What you need to know**

- **Qualitative:** rating scales (1–5, high/medium/low). Quick and subjective; good for prioritising.
- **Quantitative:** money. SLE = asset value × exposure factor; ALE = SLE × ARO. Needs reliable data.
- **Semi-quantitative:** numeric scales mapped to ranges.
- Choose by purpose, data quality and audience; use one consistent method across the enterprise.
- Cost-benefit: compare control cost with the reduction in ALE over several years, including regulatory and reputational cost.

| Trap | What the exam rewards |
|---|---|
| Quantitative is always better | Fit the method to data and purpose |
| Single-year cost figures | Multi-year view with hidden costs included |
| Different scales in each unit | One consistent method so risk aggregates |

**When it happens:** after scenarios are written. *Example: laptop theft SLE £2,000 × ARO 15 = ALE £30,000, so £8,000 a year on encryption is justified.*

**Hook:** *"Single loss times how often equals what it costs a year."*

**Exam focus:** know qualitative vs quantitative strengths and weaknesses; SLE, ARO and ALE; multi-year cost-benefit; Delphi, fault tree, event tree and bow-tie. Not needed: statistics or Monte Carlo maths.

**Question tricks:** "hard to communicate" offered as quantitative's weakness (the real weakness is data); swapped formulas (EF × ARO); single-year costs.

**Key words:** qualitative, quantitative, SLE, ARO, ALE, exposure factor, Delphi, fault tree, bow-tie, cost-benefit.

**Qualifier cues:** GREATEST limitation of quantitative → needs reliable data · PRIMARY advantage of quantitative → monetary cost-benefit · anonymous experts → Delphi · "how could this event occur, top-down" → fault tree · MOST reliable likelihood → internal plus external loss data.

**Terms to know**

- **Qualitative analysis:** rating scales such as high, medium, low.
- **Quantitative analysis:** money and probabilities.
- **Semi-quantitative analysis:** numeric scales mapped to ranges.
- **AV (asset value), EF (exposure factor):** what the asset is worth; the % lost in one event.
- **SLE = AV × EF:** the loss from one event.
- **ARO:** how many times a year the event is expected (once every 4 years = 0.25).

- **ALE = SLE × ARO:** the expected loss per year.
- **Delphi technique:** anonymous expert rounds until consensus.
- **Fault tree / event tree / bow-tie:** causes of an event (top-down) / outcomes of an event (forward) / both, with controls shown as barriers.
- **FMEA:** rating failure modes by severity, occurrence and detection.
- **Monte Carlo:** simulating many outcomes from probability ranges.
- **TCO (total cost of ownership):** all costs of a control over its life, set against the potential loss.

### Which technique is BEST when

ISACA tests technique selection through the clue in the stem. Match the clue to the technique.

| Technique | What it does | Stem clue → pick it |
|---|---|---|
| Delphi | Anonymous expert rounds until consensus | “anonymous”, avoiding groupthink or dominant voices |
| Brainstorming / workshops | Open group discussion with business owners | quick, broad identification; realism and ownership |
| Interviews | One-to-one questioning | detailed process knowledge; sensitive topics |
| Questionnaires / surveys | Structured questions to many people | wide coverage, many respondents |
| Checklists / generic libraries | Standard lists of risks | making sure nothing obvious is missed (bottom-up) |
| SWOT | Strengths, weaknesses, opportunities, threats | strategic or business-context view |
| PESTLE | Political, economic, social, technological, legal, environmental scan | external environment; emerging risk |
| Root cause analysis (5 Whys, fishbone) | Works back to why something happened | “root cause of a specific loss event” (cause-and-effect) |
| Fault tree | Top-down from a failure to its causes | “how could this event occur” |
| Event tree | Forward from an event to its outcomes | “what consequences could follow” |
| Bow-tie | Causes, event and consequences, with controls as barriers | communicating one risk; finding the path with no control |
| FMEA | Rates failure modes by severity, occurrence and detection | failures in a process, product or system |
| Human reliability analysis | Assesses the chance of human error | “exposure to personnel” or human error |
| Scenario analysis | “What if” stories for possible events | rare, high-impact or emerging risk with little data |
| Monte Carlo simulation | Runs many outcomes from probability ranges | range and probability of outcomes; needs good data |
| Sensitivity analysis | Shows which input changes the result most | which assumption matters most |
| Decision tree | Compares options with probabilities and pay-offs | choosing between response options |
| Pareto analysis | The few causes behind most losses (80/20) | focusing effort on the biggest causes |
| Cost-benefit / NPV | Compares cost of a response with loss reduction, in today’s money | justifying a control investment |

**Real life:** anonymous Delphi rounds stop the loudest manager steering a fraud-risk rating; a fishbone diagram finds why a batch of parts failed inspection; FMEA rates how a machining process could fail before it runs.

### How it’s asked: exam-style examples

Cover the right-hand columns and answer from the stem clue.

| Exam-style question | Answer | Tempting wrong option |
|---|---|---|
| Junior experts tend to defer to the CIO when rating risk. Which technique BEST reduces this influence? | Delphi | Facilitated workshop (groupthink) |
| An initial risk view is needed quickly for an undocumented subsidiary. BEST approach? | Workshops with process owners | Full vulnerability scan |
| A customer data leak happened last month. Which technique BEST identifies why? | Cause-and-effect (fishbone, 5 Whys) | Fault tree (that maps how it *could* happen) |
| To examine every way a payment outage could occur, working down from the outage, | Fault tree | Event tree |

| | | |
|---|---|---|
| use: | | |
| Which BEST shows the range of consequences that could follow a successful phishing attack? | Event tree | Fault tree |
| Which BEST helps a committee see one risk's causes, controls and consequences together? | Bow-tie | Heatmap |
| Before launching a new automated line, which BEST identifies and prioritises how each step could fail? | FMEA | Scenario analysis |
| Which technique BEST assesses a process's exposure to operator error? | Human reliability analysis | FMEA |
| Which is MOST appropriate for a rare, high-impact risk with no historical data? | Scenario analysis | Monte Carlo (needs data) |
| Management wants the probability distribution of annual losses, using reliable loss data. BEST technique? | Monte Carlo simulation | Heatmap |
| Which BEST identifies emerging external risk factors? | PESTLE | SWOT (strategy-focused) |
| Problem management wants to focus on the few causes behind most outages. BEST tool? | Pareto analysis | Event tree |
| BEST way to reduce bias in risk scenarios? | Representative historical data | A larger team of experts |
| GREATEST limitation of quantitative analysis? | Needs reliable data | Hard to communicate (it's actually easy, in money) |
| MOST reliable basis for estimating likelihood? | Internal loss data plus external industry data | Vendor threat reports |

## 2.6 Business impact analysis (BIA)

**Where it sits:** measures the impact of disruption on critical processes. It underpins continuity and impact rating.

**What you need to know**

- Identifies critical processes, dependencies and impact over time: financial, operational, legal, reputational.
- Sets **RTO** (maximum downtime), **RPO** (maximum data loss) and maximum tolerable downtime.
- Business owners supply the impact; IT designs recovery to meet the targets.
- Disputes over recovery targets are settled by BIA impact data.

| Trap | What the exam rewards |
|---|---|
| IT sets RTO and RPO | The business sets them from impact |
| Write the plan first | BIA first |
| Split the difference on RTO | Decide from impact per hour |

**When it happens:** at the planning stage of continuity, before strategy. *Example: ERP downtime costs £60k an hour, so a 2-hour RTO and hot standby are justified.*

**Hook:** *"BIA before anything: it says what matters and how fast."*

**Exam focus:** know that the BIA outputs recovery priorities and RTO, RPO and MTD; the business sets targets; shared systems follow the most critical dependent process; MTD = RTO + work recovery time. Not needed: BIA questionnaire design.

**Question tricks:** averaging conflicting estimates; IT capability setting the RTO; a list of threats offered as the BIA output.

**Key words:** BIA, RTO, RPO, MTD or MTO, work recovery time, critical process, dependency.

**Qualifier cues:** PRIMARY output of a BIA → recovery priorities and time objectives · conflicting estimates → the most critical dependent process · recovery timeframes BEST based on → the BIA.

**Terms to know**

- **BIA:** analysis of the impact of disruption on critical processes over time.
- **RTO:** maximum time to restore a system or process.
- **RPO:** maximum data loss tolerated, measured in time; drives backup frequency.
- **MTD / MTO:** the longest the business can survive without the process.
- **Work recovery time (WRT):** time to verify data and resume business after systems are restored.
- **MTD = RTO + WRT.**
- **Single point of failure:** one component whose failure stops the whole process.
- **Dependency:** a system, supplier or person a process relies on.

## 2.7 Inherent, residual and current risk

**Where it sits:** the states of a risk before and after controls.

**What you need to know**

- **Inherent:** before controls. **Residual:** after controls. **Current:** the actual level now, given how controls perform.
- A control change (added, failed, removed) changes residual risk, never inherent risk.
- Residual risk is compared with appetite to decide whether to treat or accept.
- Residual risk can't be calculated until controls are selected and evaluated. It never reaches zero.

| Trap | What the exam rewards |
|---|---|
| A failed control changes inherent risk | It changes residual risk |
| Decide the response on inherent risk | Decide on residual risk against appetite |
| Controls remove risk entirely | Some residual risk always remains |

**When it happens:** after controls are assessed, and again on any control change. *Example: audit finds a key reconciliation isn't done, so residual fraud risk moves from medium to high.*

**Hook:** *"Inherent is the storm; residual is how wet you get."*

**Exam focus:** know inherent, residual, current and target risk, what changes each, and that responses are decided on residual risk against appetite. Not needed: numeric formulas.

**Question tricks:** a control change offered as changing inherent risk; a hosting or business change offered as changing appetite; a planned fix offered as lowering the current rating.

**Key words:** inherent, residual, current, target, exposure, control effectiveness.

**Qualifier cues:** a control fails → update residual FIRST · MOST likely to change inherent → a business or exposure change · basis for a response decision → residual risk against appetite.

**Terms to know**

- **Inherent risk:** risk before any controls.
- **Residual risk:** risk after controls, as designed.
- **Current risk:** risk now, given how controls actually perform.
- **Target risk:** where risk should be after planned treatment.
- **Risk velocity:** how fast the impact arrives after the event.
- **Risk trend:** the direction a risk is moving over time.
- **Control effectiveness:** how well a control reduces the risk.

## 2.8 Risk register

**Where it sits:** the central record linking identification, analysis, ownership and response.

**What you need to know**

- Holds: scenario, owner, inherent and residual ratings, controls, response, actions, KRIs, status, dates.
- A living record, updated when risks, controls or incidents change.
- Every entry has a business owner. The register feeds reporting and aggregation.
- A risk is potential; an issue has already happened. Track issues separately, then update the risk.

| Trap | What the exam rewards |
|---|---|
| Updated once a year | Updated on every change |
| The risk function owns the entries | Business owners own their risks |
| Issues logged as risks | Issues tracked separately, feeding risk updates |

**When it happens:** maintained throughout the cycle. *Example: after a phishing incident, the phishing scenario's likelihood and residual rating are raised.*

**Hook:** *"The register is a living diary, not an annual photo."*

**Exam focus:** know the register's purpose (decisions), that owners maintain entries, that it is a living document, and risk vs issue. Not needed: tool features.

**Question tricks:** "owners haven't reviewed" vs "decisions on an inaccurate profile" for GREATEST concern; audit evidence offered as the PRIMARY purpose; the risk function owning entries.

**Key words:** register, owner, entry, issue, living document, profile.

**Qualifier cues:** PRIMARY purpose → risk-informed decisions · BEST support for accuracy → owner reviews · GREATEST concern if stale → decisions on an inaccurate profile · BEST identifies profile changes → the register.

**Terms to know**

- **Risk register:** the central record of risks, owners, ratings, responses and status.
- **Risk taxonomy:** a standard set of risk categories used across the enterprise.
- **Treatment plan:** the actions, owner and deadline for responding to a risk.

- **Issue log:** a record of things that have already gone wrong, kept separate from the risk register.

## 2.9 Risk evaluation, aggregation and prioritisation

**Where it sits:** the last step of assessment. Results are compared with appetite, ranked and communicated.

**What you need to know**

- Compare residual risk with appetite and tolerance to decide what needs treatment.
- Prioritise by impact on objectives and exposure, not by count or ease of fixing.
- Aggregate related risks: several mediums on one supplier can add up to a high concentration.
- Report to management in business terms: money, operations, objectives.
- Heat maps support judgement; they don't replace it.

| Trap | What the exam rewards |
|---|---|
| Report technical scores to executives | Report business impact |
| Rate each risk in isolation | Aggregate to find concentrations |
| Fix the easiest risks first | Rank by exposure against appetite |

**When it happens:** at the end of assessment, before response. *Example: three medium risks on one cloud supplier are combined and reported to the steering committee as one high concentration risk.*

**Hook:** *"Executives don't speak CVSS; tell them what it costs the business."*

**Exam focus:** know comparison against appetite, aggregation of common causes, reporting in business impact, and the profile shape behind a score. Not needed: heatmap design.

**Question tricks:** accepting each risk in isolation; escalating before aggregating; identical scores hiding very different likelihood and impact.

**Key words:** aggregation, concentration, heatmap, prioritisation, evaluation, common cause.

**Qualifier cues:** NEXT when several mediums share one provider → aggregate · MOST important when two risks score the same → show their different profiles · PRIMARY factor in prioritising treatment → risk rating against appetite.

**Terms to know**

- **Risk evaluation:** comparing analysed risk with appetite to decide what needs treatment.
- **Risk aggregation:** combining related risks to see the enterprise-level exposure.
- **Concentration risk:** heavy dependence on one supplier, system or person.
- **Common cause:** one root cause behind several separate risks.
- **Heatmap:** a likelihood × impact grid showing risks at a glance.
- **Risk ranking:** ordering risks for treatment by exposure against appetite.

# Domain 3: Risk Response & Reporting (32%)

This is the biggest domain: deciding what to do about risk, building and proving controls, then watching and reporting. The topics run in this order: 3.1 Response options → 3.2 Ownership → 3.3 Third parties → 3.4 Control design → 3.5 Control testing → 3.6 Monitoring and reporting → 3.7 Issues and exceptions.

## 3.1 Risk response options

**Where it sits:** the first step after evaluation. It decides what to do about risk above appetite.

**What you need to know**

- Four responses: **avoid**, **mitigate**, **transfer** (share), **accept**.
- The risk owner chooses. The practitioner presents the options with cost-benefit analysis.
- **Mitigate:** frequent risk where controls pay off. **Transfer:** rare, high-impact, mainly financial risk.
- **Avoid:** the activity is beyond appetite and not essential. **Accept:** within appetite, or formally above it.
- The response must bring residual risk within appetite. Watch for secondary risk the response creates.
- A treatment plan names actions, owner, deadline and resources.

| Trap | What the exam rewards |
|---|---|
| Practitioner picks or implements the treatment | The owner decides |
| Transfer moves accountability | Only the financial impact moves |
| Informal acceptance above appetite | Documented, approved, with an expiry |
| Mitigate whatever the cost | Cost-benefit drives the choice |

**When it happens:** straight after evaluation. *Example: mitigation costs more than the loss, so the practitioner presents the analysis and the owner chooses insurance.*

**Hook:** *"Navigator, not captain. Insurance moves the bill, not the blame."*

### Which response fits which situation

Likelihood and impact give the starting point; how essential the activity is, cost and appetite decide the final choice.

| | Low impact | High impact |
|---|---|---|
| **High likelihood** | Mitigate with routine controls, or accept if within appetite | Mitigate, often plus transfer; avoid if it can't be brought within appetite and isn't essential |
| **Low likelihood** | Accept and monitor | Transfer, plus continuity planning |

| Situation | Response | Example |
|---|---|---|
| High likelihood, high impact, activity essential | Mitigate, then transfer the residual | Ransomware on the ERP: EDR, MFA, offline backups, plus cyber insurance |
| High likelihood, high impact, activity not essential | Avoid | Stop storing card data; use a hosted payment page |
| Exceeds appetite, no cost-effective control | Avoid, or transfer if the activity is essential | Retire an unsupported internet-facing legacy app |
| Board sets zero tolerance for an outcome | Avoid | "No major compliance violations" → stop the non-compliant activity |
| Low likelihood, catastrophic impact | Transfer, plus continuity plans | Fire, flood, major breach liability |
| Mainly financial impact that can be priced | Transfer | Cyber insurance; indemnity clauses |
| Outsourcing part of a project to a specialist | Mitigation | Outsourced penetration testing |
| Reciprocal or backup agreement | Mitigation | Reciprocal recovery site |
| Residual risk within appetite | Accept (risk owner signs) | Minor outage of a low-value internal app |
| Control costs more than the expected loss | Accept (documented, economic decision), or transfer | No DoS protection on a low-value site |
| Above tolerance but must continue short-term | Accept formally: senior management, conditions, expiry | Patching freeze during peak season |
| Low likelihood, low impact | Accept and monitor | Office printer outage |

**Quick rules:** within appetite → accept; above appetite and essential → mitigate (plus transfer the residual); above appetite and not essential, or zero tolerance → avoid; rare but catastrophic, or mainly financial → transfer; control costs more than the loss → accept (documented) or transfer.

**Key points:** the response that relieves risk ownership → transference. The primary factor in choosing a response →

acceptable risk per appetite. The best information for a treatment decision → effectiveness of existing controls. The risk owner chooses; the practitioner presents options.

**Hook:** *"Common and hurts → reduce it. Rare and huge → insure it. Not worth doing → stop it. Small enough → live with it."*

### Worked cost-benefit example: choosing a response

Avoiding just the risky part wins here: it removes the most damaging data cheaply and keeps the business running.

**Scenario:** an online spares shop stores customer names, addresses and full card details.

- **SLE** (one breach: fines, forensics, notification, lost customers) = £800k
- **ARO** = 0.25, because one breach is expected every 4 years (ARO = 1 ÷ years between events)
- **ALE** = £800k × 0.25 = £200k a year, so £600k expected over 3 years. That is above appetite.

**For every option:** net benefit = (ALE before − ALE after) × years − total cost of the response, including any benefit given up.

| Option | What it involves | Loss stopped (3 yrs) | Cost (3 yrs) | Net benefit |
|---|---|---|---|---|
| Avoid the risky part | Stop storing card data; hosted payment page (£40k + £15k/yr). ALE falls to £50k | £450k | £85k | **+£365k (best)** |
| Mitigate | Encryption, WAF, MFA, monitoring (£60k + £30k/yr). ALE falls to £40k | £480k | £150k | **+£330k** |
| Transfer | Insurance covering 70% (£45k/yr). ALE retained £60k | £420k | £135k | **+£285k**, but reputation isn't insured |
| Accept | Do nothing | £0 | £0 | Expected loss £600k; above appetite |
| Avoid entirely | Close the shop | £600k | £900k of lost profit | **−£300k (worse off)** |

**What to take from it**

- Avoidance has a hidden cost: the benefit you give up. Closing the shop removes all the risk but loses more than the risk ever cost.
- In practice, combine responses: avoid storing card data, mitigate the remaining contact-detail risk, and insure the residual.
- Count costs over several years, including running costs, fees and regulatory and reputational impact.
- Cost-benefit informs the decision; the risk owner decides, and the result must bring residual risk within appetite.

**ARO quick table:** five times a year = 5 · once a year = 1 · every 2 years = 0.5 · every 4 years = 0.25 · every 10 years = 0.1 · every 50 years = 0.02.

**Hook:** *"A good response saves more than it costs. If it costs more than the risk, it's the wrong cure."*

**Exam focus:** know the four responses and when each fits; key points (transfer relieves ownership; outsourcing and reciprocal agreements are mitigation; zero tolerance means avoidance); cost-benefit including the benefit given up; the owner chooses. Not needed: insurance product types.

**Question tricks:** the practitioner choosing the treatment; informal acceptance above appetite; avoidance options that ignore the business objective.

**Key words:** avoid, mitigate, transfer, accept, cost-benefit, residual risk, appetite, insurance.

**Qualifier cues:** relieves the enterprise of ownership → transfer · PRIMARY factor in choosing a response → acceptable risk per appetite · BEST information for a treatment decision → effectiveness of existing controls · zero tolerance → avoid.

**Terms to know**

- **Avoid:** stop the activity, or the risky part of it.
- **Mitigate (reduce):** add controls to lower likelihood or impact.
- **Transfer (share):** move the financial impact to a third party (insurance, contracts).
- **Accept:** a documented decision to take no further action.
- **Secondary risk:** a new risk created by the response itself.
- **Risk treatment plan:** the actions, owner, deadline and resources for the chosen response.
- **Cost-benefit analysis:** comparing the cost of a response with the reduction in expected loss over several years.

## 3.2 Risk and control ownership

**Where it sits:** assigns accountability for each risk and each control in the response.

**What you need to know**

- **Risk owner:** accountable for the risk and response decisions. A business manager with authority and budget.

- **Control owner:** accountable that a control is designed and operating. Often a different person.
- Assign ownership at the level with authority to act.
- The best way to get remediation done: action plans with owners and deadlines.
- The practitioner facilitates assignment but never owns.

| Trap | What the exam rewards |
|---|---|
| IT owns a business risk | A business manager with authority owns it |
| Practitioner or audit owns it | The first line owns it |
| Ownership shared by a committee | One named accountable owner |

**When it happens:** when a risk is recorded and when controls are designed. *Example: each open vulnerability gets an action plan, a named owner and a deadline.*

**Hook:** *"Everybody's job is nobody's job. Name one owner."*

**Exam focus:** know risk owner vs control owner vs control operator, ownership at the level with authority, mapping risk to a business process, and accountable vs responsible. Not needed: RACI templates.

**Question tricks:** a coordinator offered as owner instead of the manager with authority; IT named as owner of a business risk; shared or committee ownership.

**Key words:** risk owner, control owner, control operator, accountable, authority, process owner.

**Qualifier cues:** BEST basis for ownership → map the risk to a business process · BEST enables ownership → authority over resources and decisions · accountable for a control operating → control owner.

**Terms to know**

- **Risk owner:** accountable for decisions about a risk; has authority and budget.
- **Control owner:** accountable that a control is designed and operating.
- **Control operator:** performs the control day to day.
- **Process owner:** accountable for a business process and its internal control requirements.
- **System owner:** selects and documents a system's security controls (in accreditation).
- **Information owner:** sets the functional and protection requirements for information.

## 3.3 Third-party and supply-chain risk

**Where it sits:** extends risk management to vendors, cloud providers and the supply chain.

**What you need to know**

- Lifecycle: due diligence → contract → ongoing monitoring → exit.
- Key clauses: right to audit, SLAs, security requirements, breach notification, data return and deletion on exit.
- Tier suppliers by criticality and data access; watch fourth-party and concentration risk.
- Assurance: SOC 2 Type II, ISAE 3402, ISO 27001 (check scope and period), questionnaires.
- No audit rights? Get alternative assurance. Accountability is never outsourced.
- At exit, get certified deletion, including backups and replicas.

| Trap | What the exam rewards |
|---|---|
| The vendor is accountable for outcomes | You stay accountable |
| Terminate when audit rights are refused | Obtain alternative assurance |
| A contract clause proves deletion | Certified evidence proves it |
| Due diligence only at onboarding | Ongoing monitoring |
| Escalate routine vendor gaps to the board | Use the standard assurance route |

**When it happens:** from due diligence before signing through to exit. *Example: before signing a cloud CRM, the practitioner reviews the provider's SOC 2 Type II report and checks its scope.*

**Hook:** *"You can outsource the work, never the accountability."*

**Exam focus:** know due diligence, validating the contract against policy, alternative assurance, certificate scope and period, exit and certified deletion, and that accountability stays with you. Not needed: SOC report section detail.

**Question tricks:** a provider that "states" certifications (the issue is due diligence); sending your policy instead of contracting for it; terminating when audit rights are refused.

**Key words:** due diligence, SOC 2, ISAE 3402, right to audit, SLA, exit, sub-processor, concentration.

**Qualifier cues:** PRIMARY concern with claimed certifications → insufficient due diligence · BEST when audit rights are refused → alternative assurance · BEST safeguard for retention → validate policies against the contract · FIRST when a supplier is acquired → assess the impact.

**Terms to know**

- **Due diligence:** checking a supplier before contracting.

- **SOC 1:** a report on controls relevant to financial reporting.
- **SOC 2:** a report on security, availability, processing integrity, confidentiality and privacy controls.
- **Type I vs Type II:** design at a point in time vs operating effectiveness over a period.
- **ISAE 3402:** the international equivalent of a SOC 1 report.
- **Right to audit:** a contract clause allowing you to audit the supplier.
- **Complementary user entity controls (CUECs):** controls the customer must operate for the supplier's report to hold.
- **Fourth-party risk:** risk from your supplier's own suppliers.
- **Source code escrow:** a third party holds the code in case the supplier fails.
- **Exit plan:** how data and service are returned, and data deleted, when the contract ends.

## 3.4 Control types, design and selection

**Where it sits:** designs the controls that carry out mitigation.

**What you need to know**

- By function: preventive, detective, corrective, plus deterrent, directive, recovery and compensating.
- By nature: administrative, also called managerial (policy, risk assessment, approvals, training), technical, also called logical (MFA, passwords, role-based access, encryption, firewalls, IDS/IPS, EDR and antivirus, DLP, audit logging, input validation, automated backups), physical (locks, badge readers, CCTV, guards, fire suppression, environmental controls). In NIST's scheme, "management" controls (policy, risk assessment, planning) are separated from "operational" ones (training, backups, incident response); see Knowledge topics.
- Preventive beats detective beats corrective. Automated beats manual for consistency.
- If the primary control isn't feasible, use a **compensating control**, for example supervisory review when segregation of duties is impossible.
- Select on cost-benefit and effect on residual risk. Use existing capability before buying new.

| Trap | What the exam rewards |
|---|---|
| Detective control where preventive is possible | Preventive first |
| Accept the risk when SoD is impossible | Add a compensating control |
| Buy a new tool | Activate existing capability first |
| Rely on an error-prone manual check | Automate it |
| The most drastic option | A proportionate fix |

**When it happens:** once mitigation is chosen. *Example: a two-person finance team can't split payment entry and approval, so the FD reviews every payment weekly.*

**Hook:** *"Lock the door before you install the camera."*

**Exam focus:** know the three classification schemes, preventive first, compensating controls when SoD isn't possible, using existing capability, and automation. Not needed: vendor products.

**Question tricks:** options drawn from a different classification scheme; a detective control where a preventive one is possible; accepting risk when SoD can't be achieved.

**Key words:** preventive, detective, corrective, compensating, directive, administrative (managerial), technical (logical), physical.

**Qualifier cues:** a policy is BEST classified as → management or administrative (directive) · SoD impossible → compensating control · MOST effective → preventive and automated.

**Terms to know**

- **Directive:** tells people what to do (policy, procedure).
- **Deterrent:** discourages the attempt (warning banners).
- **Preventive:** stops the event (MFA, SoD).
- **Detective:** finds the event (logs, IDS, reconciliations).
- **Corrective:** fixes the damage and the cause.
- **Recovery:** restores normal operations (backups, DR).
- **Compensating:** an alternative when the primary control isn't feasible.
- **General IT controls (ITGCs):** change, access and operations controls that underpin applications.
- **Application controls:** controls inside an application (input validation, matching).
- **Key control:** a control that a risk depends on most.

## 3.5 Control implementation, testing and effectiveness

**Where it sits:** puts controls in place and proves they work.

**What you need to know**

- Every new or changed control goes through change management.
- **Design effectiveness:** would it work? **Operating effectiveness:** does it work consistently over time?
- Test methods: walkthrough, inspection, re-performance, sampling. Deployed is not the same as effective.
- Owners self-assess, the second line monitors, the third line tests independently.
- Monitoring and audit run in parallel; good monitoring never justifies less audit.
- Disabled control found: re-enable it, find the root cause, review the exposure window.

| Trap | What the exam rewards |
|---|---|
| Deployed = effective | Verify operating effectiveness |
| Good monitoring means less audit | Both continue in parallel |
| Disabled control replaced with a detective one | Re-enable the preventive control |
| “No incidents” during the gap | Review transactions in the exposure window |

**When it happens:** after design, before reliance, then periodically. *Example: after MFA roll-out, log sampling confirms every remote login actually enforces it.*

**Hook:** *“Installed isn’t working. Test it.”*

**Exam focus:** know design vs operating effectiveness, evidence strength, control self-assessment, change management for controls, the disabled-control steps, and that monitoring and audit run in parallel. Not needed: sampling statistics.

**Question tricks:** deployed offered as effective; inquiry offered as sufficient evidence; good monitoring offered as a reason to reduce audit.

**Key words:** design effectiveness, operating effectiveness, re-performance, inquiry, CSA, sampling, change management.

**Qualifier cues:** BEST evidence a control works → re-performance or independent testing · FIRST on finding a disabled control → re-enable it · strong monitoring in place → audit still continues.

**Terms to know**

- **Test of design:** would the control work as designed if it were performed?
- **Test of operating effectiveness:** did the control actually work, consistently, across the whole period?
- **Inquiry:** being told by staff that the control works. The weakest evidence; never enough on its own.
- **Observation:** watching the control being performed. Stronger, but only proves that moment.
- **Inspection:** examining documents and records (sign-offs, logs, approvals).
- **Re-performance:** doing the control yourself to see if you get the same result. The strongest evidence.
- **Walkthrough:** tracing one transaction end to end to confirm the process and the control design.
- **Sampling:** testing a subset. Statistical sampling lets you project results; judgemental sampling uses the tester’s choice. The sample must cover the whole period.
- **CAATs / data analytics:** computer-assisted testing of the full population rather than a sample.
- **Control self-assessment (CSA):** control owners test their own controls. Builds ownership, but needs independent validation.
- **Continuous controls monitoring:** automated, ongoing testing of high-volume controls.
- **Exposure window:** the period a control wasn’t working, which must be reviewed.

## 3.6 Risk monitoring and reporting

**Where it sits:** ongoing tracking of risk, controls and treatment once the response is in place.

**What you need to know**

- **KRI:** early warning that exposure is changing, with thresholds tied to appetite and tolerance.
- **KPI:** measures process performance. **KCI:** measures control effectiveness.
- A good KRI is predictive, measurable, tied to a scenario and built on reliable data. Automation is secondary.
- Overdue treatment action: first find the reason and the current exposure.
- Tailor reports: the board gets the profile against appetite, trends and business impact.
- Validate data sources before aggregating. Monitor and report emerging risk.

| Trap | What the exam rewards |
|---|---|
| Most important KRI quality is automation | Early-warning value |
| Relax the threshold after a breach | Report the breach to the owner |
| Escalate every overdue action | Understand the reason and exposure first |
| Technical metrics for the board | Business-impact trends |
| Audits or certificates catch gradual drift | Continuous KRIs do |

**When it happens:** continuously, once the response is in place. *Example: the limit is “critical vulnerabilities patched within 14 days”. The KRI tracks how many critical vulnerabilities are still open after 10 days. At 5 it turns amber, giving the owner time to act before the limit is breached. If any pass 14 days it turns red, and the practitioner reports the breach to the risk*

*owner straight away, in business-impact terms.*

**Hook:** *"A KRI is the smoke alarm, not the fire report."*

**Exam focus:** know KRI vs KPI vs KCI, early warning, thresholds set from tolerance, matching the metric to the process objective, reporting techniques, emerging risk, and overdue actions. Not needed: dashboard tools.

**Question tricks:** incident metrics offered for problem management; relaxing a threshold after a breach; automation offered as the most important KRI quality.

**Key words:** KRI, KPI, KCI, threshold, trend, dashboard, heatmap, emerging risk.

**Qualifier cues:** MOST important KRI characteristic → early warning · MOST effective KRI for problem management → recurring incidents · BEST for senior management reporting → dashboards · FIRST on a KRI breach → report to the risk owner.

**Terms to know**

- **KRI:** a key risk indicator; early warning that exposure is changing.
- **KPI:** a key performance indicator; how well a process performs.
- **KCI:** a key control indicator; how well a control works.
- **Leading vs lagging indicator:** predicts a future change vs confirms what already happened.
- **Threshold / trigger:** the KRI level that prompts action.
- **Dashboard:** near-real-time view of KRIs and KCIs with red, amber and green status.
- **Scorecard:** metrics against targets (often a balanced scorecard).
- **Horizon scanning:** looking ahead for emerging risk.
- **Data validation:** checking data is accurate, complete and timely before reporting.

**Matching metrics to processes:** MTTD and MTTR are KPIs for incident management; recurring incidents are the KRI for problem management; days critical patches stay open is the KRI for patching; phishing report rate is the KRI for awareness. Pick the metric that shows whether the process is failing at its own purpose.

### Reporting formats and who they're for

The board wants the big picture in business terms; owners want detail they can act on.

| Format | What it shows | Best audience | Stem clue → pick it |
|---|---|---|---|
| Risk profile against appetite | Where risk sits compared with the agreed appetite | Board | "BEST enables board oversight" |
| Heatmap (risk matrix) | Risks plotted by likelihood and impact | Board, executives | snapshot of top risks; prioritisation; concentrations |
| Dashboard | Near-real-time KRIs and KCIs, red/amber/green, with trends | Senior management, risk owners | "MOST suitable for reporting IT business risk to senior management" |
| Trend chart | Direction of a risk or KRI over time | Board, risk committee | whether risk is improving or worsening |
| Scorecard / balanced scorecard | Metrics against targets across perspectives (financial, customer, internal process, learning) | Management | performance against objectives |
| Radar (spider) chart | Current vs target maturity across several areas | Management, steering committee | maturity or capability gap |
| Bar or column chart | Comparison across units or categories | Management | comparing sites, units or periods |
| Pareto chart | The few causes behind most incidents | Problem management, process owners | where to focus root-cause effort |
| Bow-tie diagram | Causes, controls and consequences of one risk | Workshops, stakeholders | explaining a single risk and its control gaps |
| Risk register report | Full detail per risk | Risk owners, second line | managing individual risks |

**Board reporting rules:** aggregated, in business language, showing the profile against appetite, trends, top risks, emerging risk and decisions needed. Technical detail and individual risks go to owners, not the board.

**Real life:** the board gets a one-page heatmap of the top 10 risks against appetite with trend arrows; the operations director gets a dashboard of production KRIs; site managers get a bar chart of open audit findings by site.

## 3.7 Issue, finding and exception management

**Where it sits:** handles gaps that have been found (issues and findings) and approved departures from policy (exceptions).

**What you need to know**

- **Issue or finding:** log it, assign an owner, find the root cause, agree an action plan, track and verify closure.
- **Exception:** assess the risk → owner and senior management approve → compensating controls → expiry date.
- Expired exceptions need a fresh assessment and re-approval. No automatic renewal.
- Exceptions are prospective only. Never back-date one to cover an accidental gap.
- Senior management awareness of authorised exceptions is the key control.
- **Exemption:** a formally justified, longer-term scope-out. **Exception:** temporary.
- Recurring issues point to a systemic root cause.

| Trap | What the exam rewards |
|---|---|
| Practitioner approves the exception | Owner and senior management approve |
| Auto-renew an expired exception | Re-assess and re-approve |
| Back-dated exception covers a gap | Treat it as an issue; review the exposure window |
| Patch the same issue again | Fix the systemic root cause |
| Close a finding on the owner's word | Verify closure |

**When it happens:** whenever a gap is found or a deviation is requested. *Example: a legacy app can't take complex passwords, so after assessment the owner approves a six-month exception with MFA in front.*

**Hook:** *"An exception is a risk with a permission slip: signed, conditioned and dated."*

**Exam focus:** know issue vs exception vs exemption, approval levels, expiry dates, no back-dating, the root cause of recurring issues, and verified closure. Not needed: workflow tool details.

**Question tricks:** the practitioner approving an exception; automatic renewal; a back-dated exception covering a gap.

**Key words:** issue, finding, exception, exemption, expiry, compensating control, root cause.

**Qualifier cues:** FIRST on an exception request → assess the risk · BEST fix when authorised exceptions keep bypassing a control → improve senior management awareness · expired exception → re-assess and re-approve.

**Terms to know**

- **Issue / finding:** a gap or failure that has been identified.
- **Exception (waiver):** a temporary, approved departure from policy with an expiry date.
- **Exemption:** a justified, longer-term exclusion from a requirement.
- **Root cause analysis:** finding why something happened (5 Whys, fishbone diagram).
- **Corrective action plan:** the actions, owner and date to fix an issue.
- **Closure verification:** independently confirming that a fix actually works.

# Domain 4: Technology & Security (20%)

This domain tests technology through a risk lens: the same governance rules applied to IT operations, projects, resilience, data and security. The topics run in this order: 4.1 EA and IT ops → 4.2 Security frameworks → 4.3 Projects and SDLC → 4.4 Continuity → 4.5 Privacy → 4.6 Emerging tech → 4.7 Data lifecycle → 4.8 Awareness.

## 4.1 Enterprise architecture and IT operations

**Where it sits:** the technology foundation that business processes run on.

**What you need to know**

- Enterprise architecture aligns IT with business strategy and avoids duplicated or orphaned systems.
- Asset and configuration management (CMDB) is the inventory everything else depends on.
- Incident management restores service; problem management finds and removes root cause.
- Change management covers every change. Emergency changes skip prior approval but are always retrospectively reviewed and authorised.
- Capacity, availability and SLA monitoring keep operations within agreed levels.

| Trap | What the exam rewards |
|---|---|
| Emergency change needs no approval | Retrospective review and authorisation |
| Incident closed = problem solved | Problem management finds root cause |
| Technology chosen first | Architecture driven by business strategy |

**When it happens:** in daily operations and at every change. *Example: a hotfix goes into production at 2am; the CAB reviews and signs it off the next morning.*

**Hook:** *"Break the glass in an emergency, then explain why you broke it."*

**Exam focus:** know the purpose of EA and roadmaps, change management (including emergency changes), incident vs problem management, DevOps controls, and the CMDB. Not needed: ITIL process detail.

**Question tricks:** "emergency change, so no approval needed"; incident metrics offered for problem management; a closed incident offered as a solved problem.

**Key words:** enterprise architecture, roadmap, CMDB, change management, emergency change, incident, problem, DevOps.

**Qualifier cues:** MOST important after an emergency change → retrospective review and authorisation · PRIMARY benefit of EA → alignment with the business · problem management KRI → recurring incidents.

**Terms to know**

- **Enterprise architecture (EA):** the blueprint linking business, data, applications and technology (TOGAF, Zachman).
- **Technology roadmap:** the planned adoption, upgrade and retirement of technology over time.
- **Technical debt:** the future cost of shortcuts or outdated technology.
- **CMDB / configuration item:** the database of IT components and their relationships.
- **Change advisory board (CAB):** the group that reviews and approves changes.
- **Emergency change:** an urgent change that skips prior approval but is authorised afterwards.
- **Incident vs problem vs known error:** a service disruption / its underlying cause / a cause that's diagnosed but not yet fixed.
- **DevOps / CI-CD:** combined development and operations with automated, frequent releases.

**Reliability and incident metrics**

- **MTTD (mean time to detect):** average time to spot an incident. *Real life: ransomware noticed 6 hours after encryption started.*
- **MTTR (mean time to repair or restore):** average time to restore service after a failure. *Real life: the ERP takes 4 hours to bring back after a crash.*
- **MTBF (mean time between failures):** average running time between failures, a measure of reliability. *Real life: a CNC controller PC fails about every 2,000 hours.*
- **MTTF (mean time to failure):** expected life of an item that is replaced, not repaired. *Real life: a server's power supply.*
- **Availability = MTBF ÷ (MTBF + MTTR).** *Real life: 2,000 ÷ (2,000 + 4) ≈ 99.8% available.*
- **Exam use:** MTTD and MTTR measure incident management (KPIs); the number of recurring incidents measures problem management (KRI); MTBF measures reliability and resilience.

## 4.2 Information security frameworks, standards and controls

**Where it sits:** the security control set that protects information assets.

**What you need to know**

- Frameworks and standards: ISO 27001/27002, NIST CSF, CIS Controls. Tailor them to the enterprise.
- Core principles: defence in depth, least privilege, need to know, segregation of duties.
- Identity and access: joiner-mover-leaver process, periodic access reviews, privileged access management, MFA.
- Orphaned accounts usually mean the leaver process isn't linked to deprovisioning.
- Cloud shared responsibility: whoever controls a layer secures it. In IaaS the customer patches the OS and above.
- Security certification covers CIA (confidentiality, integrity, availability), not privacy law.

| Trap | What the exam rewards |
|---|---|
| More frequent access reviews fix orphaned accounts | Link the leaver process to deprovisioning |
| The cloud provider patches everything | Shared responsibility by layer |
| Shared admin accounts for convenience | Individual accountability (shared accounts = repudiation risk) |
| ISO 27001 = compliant transfers | Certification ≠ privacy compliance |

**When it happens:** across the whole system lifecycle. *Example: moving an app to IaaS, the organisation keeps OS patching in its own weekly cycle.*

**Hook:** *"The landlord fixes the roof; you lock your own front door."*

**Exam focus:** know CIA, least privilege, SoD, the identity lifecycle, repudiation risk from shared accounts, cryptography basics, cloud shared responsibility, network controls and zero trust. Not needed: algorithms or key lengths.

**Question tricks:** more frequent access reviews offered to fix orphaned accounts; the provider patching the OS in IaaS; IDS vs IPS (detects vs blocks).

**Key words:** CIA, least privilege, SoD, MFA, RBAC, digital signature, shared responsibility, zero trust, IDS, IPS.

**Qualifier cues:** MAIN concern with shared accounts → repudiation · integrity plus non-repudiation → digital signatures · MOST effective against insiders → RBAC · who patches the OS in IaaS → the customer.

**Terms to know**

- **CIA triad:** confidentiality, integrity, availability.
- **Authentication factors:** something you know, have or are. MFA uses two different types.
- **Least privilege / need to know:** only the access required for the job.
- **RBAC:** access granted by job role.
- **Privileged access management (PAM):** controls over admin accounts.
- **Joiner-mover-leaver:** the access lifecycle as people join, change role and leave.
- **Repudiation / non-repudiation:** denying an action / proving who did it.
- **Symmetric vs asymmetric encryption:** one shared key / a public and private key pair.
- **Hashing:** a one-way fingerprint that proves integrity.
- **Digital signature:** a hash signed with a private key, giving integrity, authentication and non-repudiation.
- **IDS vs IPS:** detects intrusions / blocks them.
- **DMZ:** a network zone that isolates public-facing systems.
- **Zero trust:** verify every request; trust nothing by network location.
- **IaaS / PaaS / SaaS:** the customer secures the OS and up / the apps and data / the data and access.

## 4.3 Project management and the SDLC

**Where it sits:** how new systems are planned, built and released.

**What you need to know**

- SDLC: feasibility → requirements → design → build → test → implement → post-implementation review.
- Security requirements are defined at requirements, designed at design, verified in testing.
- Separate development, test and production. Developers don't promote their own code.
- Use masked or synthetic data in test; production personal data needs data-owner approval.
- Project risk: business case, steering committee, scope creep, sponsor accountability.
- A post-implementation review confirms benefits and controls were delivered.

| Trap | What the exam rewards |
|---|---|
| Security added in testing or at go-live | Security defined at requirements |
| Developers move code to production | SoD between dev and prod |
| Production data copied to test freely | Data owner authorises; mask the data |

**When it happens:** from the business case to the post-implementation review. *Example: encryption at rest is written into the requirements of a new web app before design starts.*

**Hook:** *"Put the locks on the blueprint, not on the finished house."*

**Exam focus:** know the SDLC phases, security at requirements, threat modelling at design, SoD between development and production, test data, project and portfolio governance, Agile risks, and cut-over methods. Not needed: coding.

**Question tricks:** security added at testing; which cut-over is riskiest (abrupt); developers promoting their own code.

**Key words:** SDLC, requirements, design, UAT, regression, cut-over, Agile, portfolio, business case.

**Qualifier cues:** FIRST risk involvement in the SDLC → planning · BEST phase for security requirements → requirements · GREATEST data-consistency risk at cut-over → abrupt changeover.

**Terms to know**

- **SDLC phases:** feasibility, requirements, design, build, test, implement, post-implementation review.
- **Waterfall / Agile / DevSecOps:** sequential / iterative sprints / continuous delivery with security built in.
- **Unit, integration, system testing:** one component / components together / the whole system.
- **UAT (user acceptance testing):** the business confirms the system meets its needs.
- **Regression testing:** retesting after a change to check nothing else broke.
- **Cut-over methods:** parallel (safest), pilot, phased, abrupt or big-bang (riskiest).
- **Post-implementation review:** checks benefits and controls were delivered.
- **Business case:** the justification for a project (benefits, costs, risks).
- **Portfolio / programme / project:** all investments / related projects with a shared benefit / one temporary piece of work.
- **Scope creep:** uncontrolled growth in project scope.

## 4.4 Business continuity and resilience

**Where it sits:** keeping the business running through disruption.

**What you need to know**

- Lifecycle: BIA → strategy → plan → test → maintain.
- **BCP** covers people, facilities, supply chain and communications. **DRP** is its IT-only subset.
- Senior management owns the BCP. The business sets RTO and RPO; IT engineers to meet them.
- Testing ladder: checklist → tabletop → simulation → parallel → full interruption. Untested plans start with tabletop.
- Re-test after any significant change. A test that shows the RTO can't be met is a material risk to escalate.
- Resilience designs out single points of failure in advance; BCP and DRP respond afterwards.

| Trap | What the exam rewards |
|---|---|
| Write the plan first | BIA first |
| BCP = DRP | DRP is only the IT part |
| Full interruption test on an untested plan | Start with a tabletop |
| No incidents = plan works | An untested plan is an unknown plan |
| Concern = change process failed | Concern = the business can't recover |

**When it happens:** BIA at planning; testing at least annually and after major change. *Example: a migrated patient-records system leaves the BCP pointing at the old platform, so the business can't recover.*

**Hook:** *"BIA before anything; never crash-test a car you've never sat in."*

**Exam focus:** know BIA → strategy → plan → test → maintain; BCP vs DRP vs IRP; the testing ladder; recovery sites vs MTO; backup types; escalating a failed RTO test. Not needed: recovery site contract details.

**Question tricks:** a DRP offered as readiness for any unexpected event (that's the IRP); a full interruption test first; a warm site for a very low MTO.

**Key words:** BCP, DRP, IRP, RTO, RPO, MTO, hot, warm and cold sites, tabletop, full interruption.

**Qualifier cues:** BEST evidence of readiness for unexpected events → IRP · very low MTO → owned hot site · test with major operational impact → full interruption · FIRST test of an untested plan → tabletop.

**Terms to know**

- **IRP / DRP / BCP:** respond to any incident / recover IT after a major disruption / keep the business running.
- **Crisis management:** leadership and communication during a major event.
- **Hot, warm, cold, mobile, mirrored site:** ready in minutes / hours to days / weeks / delivered on demand / running in parallel.
- **Reciprocal agreement:** two organisations agree to host each other in a disaster.
- **Test types:** checklist, tabletop, simulation, parallel, full interruption (least to most disruptive).
- **Full / incremental / differential backup:** everything / changes since the last backup / changes since the last full backup.
- **3-2-1 rule:** three copies, on two media types, one off-site.
- **High availability / failover:** systems designed to keep running / automatic switch to a standby system.

## 4.5 Data privacy and data protection

**Where it sits:** the legal and governance layer over personal data.

**What you need to know**

- Privacy is the right to control how personal data is used. Security is the mechanism that enforces it.
- Principles: purpose limitation, data minimisation, consent, storage limitation, rights of data subjects.
- Roles: **controller** decides purpose and means; **processor** acts for the controller. Data owner decides; custodian implements.
- A DPIA comes before any new high-risk processing, at the design stage.
- Consent is purpose-bound: a new purpose needs a new legal basis or fresh consent.
- Cross-border transfers need legal safeguards. Security certification does not provide them.

| Trap | What the exam rewards |
|---|---|
| Collect now, assess later | DPIA before processing |
| Original consent covers related uses | New purpose needs a new basis |
| ISO 27001 permits the transfer | Legal adequacy is separate |
| Fix the notice wording | The real risk is processing without a basis |

**When it happens:** at design, before processing starts. *Example: a loyalty programme profiling customers is halted until the DPIA is done and reviewed by the DPO.*

**Hook:** *"Privacy is the promise, security is the padlock."*

**Exam focus:** know the privacy principles, DPIA before processing, controller vs processor, purpose limitation, cross-border transfer, and privacy by design. Not needed: article numbers of specific laws.

**Question tricks:** ISO 27001 offered as privacy compliance; original consent offered to cover a new use; fixing the notice wording offered as the GREATEST risk.

**Key words:** PII, DPIA or PIA, consent, purpose limitation, controller, processor, cross-border transfer, privacy by design.

**Qualifier cues:** FIRST before new processing → DPIA · GREATEST benefit for new infrastructure → privacy by design · MOST significant gap with a certified overseas provider → legality of the transfer.

**Terms to know**

- **PII / personal data:** information that identifies a person.
- **Data subject:** the person the data is about.
- **Controller / processor:** decides the purpose and means / processes on the controller's behalf.
- **DPO:** the data protection officer; advises and monitors compliance.
- **DPIA / PIA:** a privacy impact assessment before high-risk processing.
- **Lawful basis:** the legal reason for processing (consent, contract, legal obligation and others).
- **Purpose limitation / data minimisation / storage limitation:** use only for the stated purpose / collect only what's needed / keep only as long as needed.
- **Anonymisation vs pseudonymisation:** irreversibly unidentifiable (out of scope) / replaced identifiers (still personal data).
- **Cross-border transfer:** sending data to another jurisdiction, which needs legal safeguards.
- **Privacy by design:** building privacy into systems from the start.

## 4.6 Emerging technologies and AI

**Where it sits:** new technology run through the same risk process: inventory → assess → own → govern → monitor.

**What you need to know**

- Assess emerging technology at the business case stage, against objectives and appetite.
- An AI use-case inventory comes first. Its purpose is to make risk visible and ownable.
- AI risk factors: data leakage, bias, hallucination, lack of explainability, model drift, shadow AI.
- The vendor builds the model; the business owner stays accountable for outcomes.
- Model drift needs continuous KRIs, for example forecast accuracy against actuals.
- Keep a human in the loop for high-impact decisions.

| Trap | What the exam rewards |
|---|---|
| Ban the technology | Assess it against appetite |
| Write the policy before understanding use | Assess first, then policy, then controls |
| The vendor answers for model errors | The business owner is accountable |
| Certification proves ongoing performance | Continuous monitoring catches drift |

**When it happens:** at the business case, before procurement, then continuously. *Example: staff pasting client files into public AI tools triggers a risk assessment before any policy or block.*

**Hook:** *"New tech, same rules: assess it, own it, govern it, watch it."*

**Exam focus:** know that new technology follows the same risk process, inventory comes first, assessment comes before policy, accountability stays with the business, drift needs KRIs, and the basics of IoT and quantum risk. Not needed: how AI models work.

**Question tricks:** banning the technology; the vendor held accountable for the model; certification offered as proof of ongoing performance.

**Key words:** AI, model drift, shadow AI, IoT, blockchain, quantum, inventory, emerging technology.

**Qualifier cues:** FIRST when the technology is already in use → assess the risk · PRIMARY purpose of an AI inventory → risk visibility and ownership · BEST early warning of drift → KRIs.

**Terms to know**

- **Model drift:** an AI model's accuracy declining as real-world data changes.
- **Hallucination:** confident but wrong AI output.
- **Explainability:** being able to show why an AI made a decision.
- **Shadow AI / shadow IT:** technology used without approval or oversight.
- **IoT:** internet-connected devices, often hard to patch.
- **OT / ICS:** operational technology and industrial control systems on the shop floor.
- **Blockchain:** a tamper-evident shared ledger; records can't easily be deleted.
- **Harvest now, decrypt later:** stealing encrypted data today to break it with future quantum computers.
- **Crypto-agility:** being able to switch encryption methods quickly.
- **RPA:** robotic process automation; software bots doing repetitive tasks.

**Exam pattern: emerging risk + new technology + disaster recovery.** The answer is the **new vulnerability the technology introduces into the recovery capability itself**.

- AI used in DR → **adversarial attacks on the model** (manipulated inputs that make it fail or mislead).
- Quantum computing and DR → **vulnerabilities in today's encryption algorithms** protecting backups and recovery data.
- Discard engineering hurdles such as scalability or performance: that's the wrong domain for a risk question.

*Real life:* an AI tool that decides which systems to fail over first could be fed manipulated data to pick the wrong ones; encrypted off-site backups could be harvested now and decrypted later by quantum computers.

## 4.7 Data lifecycle management

**Where it sits:** data moves from create → store → use → share → archive → destroy.

**What you need to know**

- The data owner classifies at creation. Classification drives encryption, access, retention and disposal.
- Retention is set by the owner from legal, regulatory and business need.
- A legal hold overrides the retention schedule.
- Secure disposal matches the classification, and third-party destruction is verified with a certificate.
- Every copy follows the lifecycle: backups, test copies, archives, cloud replicas.
- Reclassify when the data changes in nature or sensitivity.

| Trap | What the exam rewards |
|---|---|
| IT classifies data | The owner classifies |
| Wipe as soon as the system is retired | Confirm retention and holds first |
| Delete records past retention despite litigation | Suspend; legal sets the hold scope |
| A contract clause proves deletion | Certified evidence, including backups |
| An automated tool replaces owners | Tools support; owners decide |

**When it happens:** classification at creation; retention and disposal at the end of life. *Example: before a legacy HR system is wiped, the data owner confirms which records must be kept.*

**Hook:** *"Classify at birth, retain by law, destroy with proof."*

**Exam focus:** know classification by the owner at creation, retention and legal hold, secure disposal with proof, that every copy counts, and reclassifying when data changes. Not needed: disposal techniques in depth.

**Question tricks:** a contract clause offered as proof of deletion; a tool offered to replace owner classification; wiping before retention is checked.

**Key words:** classification, retention, legal hold, disposal, data remanence, certificate of destruction, data owner.

**Qualifier cues:** FIRST before wiping → confirm retention with the owner · GREATEST assurance of deletion → certified

evidence including backups · MAIN concern on disposal → data remanence.

**Terms to know**

- **Data lifecycle:** create, store, use, share, archive, destroy.
- **Classification levels:** typically public, internal, confidential, restricted.
- **Retention schedule:** how long each type of record must be kept.
- **Legal hold:** a freeze on deleting data relevant to litigation or investigation.
- **Archiving:** moving inactive data to long-term storage.
- **Overwriting, degaussing, crypto-shredding, physical destruction:** secure disposal methods.
- **Data remanence:** data that remains recoverable after deletion.
- **Certificate of destruction:** evidence that a supplier securely destroyed data.
- **DLP (data loss prevention):** tools that detect and block sensitive data leaving.

## 4.8 Security awareness training

**Where it sits:** the people layer of defence in depth, a preventive administrative control.

**What you need to know**

- Its purpose is behaviour change that supports policy, not knowledge alone.
- Measure effectiveness by behaviour: phishing click and report rates, human-error incidents. Use trends.
- Make it role-based for finance, admins, developers, executives and third parties.
- Deliver it at onboarding, before access, then periodically and when threats or roles change.
- Senior management sponsorship sets the culture.
- Repeated errors by trained staff point to a process fix, not more training.

| Trap | What the exam rewards |
|---|---|
| 100% completion = effective | Behaviour metrics prove effect |
| Discipline staff who fail simulations | Use results to improve the programme |
| More training after repeat fraud | Fix the process (independent verification) |
| Contractor's own training is enough | Your policies, role-based, before access |

**When it happens:** at onboarding before access, then ongoing. *Example: a new AP clerk completes payment-fraud training before their AP access is switched on.*

**Hook:** *"Ticks prove they turned up; clicks prove they learned."*

**Exam focus:** know training as a control for behaviour, behaviour metrics, role-based training before access, sponsorship, and the process fix for repeated errors. Not needed: training content design.

**Question tricks:** completion rates offered as effectiveness; signatures or discipline offered as the fix; more training after repeated fraud by trained staff.

**Key words:** awareness, phishing simulation, role-based training, behaviour, completion, sponsorship.

**Qualifier cues:** BEST metric → behaviour trend (reports and clicks) · MOST important reason for awareness → reduce social engineering · MOST effective way to make a policy work → user education.

**Terms to know**

- **Awareness vs training vs education:** knowing the risk / skills for a role / deep professional knowledge.
- **Role-based training:** content targeted at high-risk roles.
- **Phishing simulation:** fake phishing emails to test staff behaviour.
- **Click rate / report rate:** % who fall for it / % who report it.
- **Social engineering:** manipulating people into breaking security.
- **Spear phishing / whaling / vishing / pretexting / tailgating:** targeted phishing / targeting executives / by phone / using a made-up story / following someone through a secure door.
- **BEC (business email compromise):** fraud using hijacked or spoofed business email, often payment fraud.
- **Acceptable use policy (AUP):** the rules for using company systems and data.

# Knowledge topics the exam tests

The briefs above focus on judgement (who decides, what comes first). The exam also tests models, classifications and terms. These are the knowledge areas most likely to appear.

## Governance and risk knowledge

### IT organisational structures

| Structure | Clue in the stem | Main risk |
|---|---|---|
| Centralised | One body makes all IT decisions and holds the budget | Slow; drives shadow IT |
| Decentralised | Each unit runs its own IT and budget | Inconsistent controls; poor enterprise view |
| Federated / hybrid | Central standards, local execution | Unclear decision rights |
| Divisional | IT aligned to product, region or unit | Silos; hard to aggregate risk |
| Matrix | Dual reporting lines | Conflicting priorities |
| Project-based | Teams form around projects, then disband | Ownership lost after the project |

**Three ways to classify controls** (read the options to see which scheme is in play)

| Scheme | Categories |
|---|---|
| By who or what runs it (NIST) | **Management** (policy, risk assessment, planning) · **Operational** (people: training, backups, incident response) · **Technical** (systems: MFA, firewalls, logging) |
| By function | Directive · deterrent · preventive · detective · corrective · recovery · compensating |
| By nature | Administrative · technical (logical) · physical |

A security policy is a **management** control (directive by function).

**Document hierarchy**

- **Policy:** intent and allowable limits of behaviour; approved by senior management; technology-neutral.
- **Standard:** mandatory specifics, including baselines.
- **Procedure:** step-by-step, platform-specific instructions.
- **Guideline:** recommended, non-mandatory practice.

**Ethics and conflict of interest**

- Conflicting roles: a supplier who is also the architect, audit designing controls, a practitioner owning risk, one person requesting and approving.
- FIRST: identify the conflict and record it in the risk register. Then treat it: independent review, role separation, disclosure, contract terms.
- ISACA Code duties: objectivity, due care, competence, confidentiality, honest reporting to the right parties.

**Benchmarking order:** select the standard → assess the current state → identify gaps → close them.

**Risk assessment techniques**

| Technique | What it does |
|---|---|
| Delphi | Anonymous expert rounds until consensus; avoids groupthink |
| Bow-tie | Causes → event → consequences, with preventive controls left and mitigating controls right |
| Fault tree | Works top-down from a failure to its causes |
| Event tree | Works forward from an event to its possible outcomes |
| FMEA | Rates failure modes by severity, occurrence and detection |
| Monte Carlo | Simulates many outcomes from probability ranges |
| Root cause analysis | 5 Whys, fishbone (Ishikawa) diagram |

**Maturity models (CMMI, COBIT capability levels 0–5):** incomplete → initial → managed → defined → quantitatively managed → optimising. Use them to compare current with target maturity and build an improvement roadmap.

**Capability and maturity models: what you need for the exam**

- Purpose: **gap analysis**. Measure the current level against the desired level, then build a roadmap.
- The target comes from business need and appetite, **not** automatically level 5.
- Capability = one process; maturity = a whole area or the organisation. ISACA often treats them as one idea.

- Not needed: exact level definitions or model versions.

**How questions try to trick you here**

- “Benchmarking what other enterprises do” → that’s benchmarking, not a capability model.
- “Reaching the highest maturity level” → wrong target; aim for the level the business needs.
- “Identifying vulnerabilities in processes” → that’s a vulnerability assessment, not maturity.

## Technology and continuity knowledge

**Incident response lifecycle:** preparation → detection and analysis → containment, eradication, recovery → post-incident lessons learned.

| Plan | Scope | Triggered when |
|---|---|---|
| IRP | Any unexpected event | An event is detected |
| DRP | IT recovery after major disruption | An incident escalates past the threshold |
| BCP | Business operations: people, facilities, suppliers | Business processes are disrupted |

FIRST action on a confirmed incident: contain it. Readiness for unexpected events is best shown by the IRP.

**Recovery sites** (lower MTO or RTO → hotter, more dedicated site; RTO must be shorter than MTO)

| Site | Recovery time | Cost | Key risk |
|---|---|---|---|
| Mirrored / redundant | Near zero | Highest | Cost |
| Hot | Minutes–hours | High | Oversubscription if contracted or shared |
| Warm | Hours–days | Medium | Data restore time |
| Cold | Days–weeks | Low | Too slow for critical systems |
| Mobile | Days | Medium | Delivery and set-up time |
| Reciprocal agreement | Varies | Low | Incompatibility, lack of capacity |

**Backup types**

- **Full:** everything; slowest backup, simplest restore.
- **Incremental:** changes since the last backup of any type; fastest backup, slowest restore (needs every increment).
- **Differential:** changes since the last full; restore = full + latest differential.
- Keep copies offline or immutable against ransomware, and test restores; an untested backup is unproven.

**Cloud models**

- Service: **IaaS** (customer secures OS and up) → **PaaS** (customer secures apps and data) → **SaaS** (customer secures data and access).
- Deployment: public, private, hybrid, community.
- Key risks: data location and sovereignty, vendor lock-in, misunderstanding shared responsibility.

**Cryptography basics**

- **Symmetric:** one shared key; fast; bulk encryption (AES). The risk is key distribution.
- **Asymmetric:** public/private key pair; key exchange and digital signatures.
- **Hashing:** one-way; proves integrity.
- **Digital signature:** hash signed with the sender’s private key = integrity, authentication, non-repudiation.
- Key management is the critical control.

**Network controls:** firewall filters traffic · IDS detects · IPS prevents · DMZ isolates public-facing systems · segmentation limits spread · VPN protects data in transit · NAC checks devices before they connect.

**SDLC methods and testing**

- Methods: waterfall (sequential), agile (iterative), DevOps / DevSecOps (continuous, security built in).
- Testing: unit → integration → system → **UAT** (business sign-off) → **regression** (after any change).
- Cut-over: parallel (safest), pilot, phased, big-bang (riskiest).

**Service agreements: SLA** between provider and customer · **OLA** between internal teams · **underpinning contract** with a third-party supplier.

**Data classification levels:** typically public → internal → confidential → restricted. The data owner classifies.

# Official outline check: every subtopic mapped

Every subtopic in ISACA's current CRISC exam content outline is now covered in this guide. The table maps each one to where it sits; rows marked "Added below" are filled in the next section. Source: ISACA CRISC Exam Content Outline.

| Code | Official subtopic | Covered in |
|---|---|---|
| 1A1 | Strategy, goals and objectives | 1.1 |
| 1A2 | Organisational structure, roles and responsibilities | 1.2; Knowledge topics (IT structures) |
| 1A3 | Organisational culture and ethics | 1.3; 1.7; Knowledge topics (ethics) |
| 1A4 | Policies and standards | 1.4; Knowledge topics (document hierarchy) |
| 1A5 | Business processes and resilience (DRP, BCP) | 1.4; 2.6; 4.4; Knowledge topics; Added below |
| 1A6 | Organisational asset management | Added below |
| 1B1 | Enterprise risk management | 1.5 |
| 1B2 | Lines of defence | 1.5 |
| 1B3 | Risk profile | 1.6 |
| 1B4 | Risk appetite and tolerance | 1.6 |
| 1B5 | Frameworks, legal, regulatory, contractual | 1.5; 1.7 |
| 2A1 | Risk events | 2.1 |
| 2A2 | Threat modelling and threat landscape | 2.2 |
| 2A3 | Vulnerability management | 2.3 |
| 2A4 | Risk scenario development and evaluation | 2.4 |
| 2B1 | Risk assessment concepts and standards | 2.5; Added below |
| 2B2 | Business impact analysis | 2.6 |
| 2B3 | Risk register | 2.8 |
| 2B4 | Risk analysis methodologies | 2.5; Knowledge topics (techniques) |
| 2B5 | Inherent and residual risk | 2.7 |
| 3A1 | Risk response options | 3.1 |
| 3A2 | Risk and control ownership | 3.2 |
| 3A3 | Vendor and supply chain risk | 3.3 |
| 3A4 | Issues, findings, exceptions, exemptions | 3.7 |
| 3B1 | Control frameworks, types and standards | 3.4; Knowledge topics (classification) |
| 3B2 | Control design, selection, implementation, analysis | 3.4; 3.5 |
| 3B3 | Control testing methodologies | 3.5; Added below |
| 3C1 | Risk action plans | 3.1; 3.6 |
| 3C2 | Data collection, aggregation, analysis, validation | 2.9; Added below |
| 3C3 | KRIs, KCIs, KPIs | 3.6 |
| 3C4 | Risk and control monitoring techniques | Added below |
| 3C5 | Reporting techniques (heatmaps, scorecards, dashboards) | Added below |
| 3C6 | Monitoring and reporting of emerging risk | 3.6; Added below |
| 4A1 | Technology principles | Added below |
| 4A2 | Technology roadmaps and enterprise architecture | 4.1; Added below |
| 4A3 | Operations management (change, assets, DevOps, problems, incidents) | 4.1; Knowledge topics (incident response); Added below (DevOps) |
| 4A4 | System development life cycle | 4.3; Knowledge topics (SDLC methods, testing) |
| 4A5 | Data lifecycle management | 4.7 |
| 4A6 | Portfolio and project management (Agile) | 4.3; Added below |
| 4A7 | Technology resilience, disaster response and recovery | 4.4; Knowledge topics (sites, backups) |

| | | |
|---|---|---|
| 4A8 | Emerging technologies | 4.6; Added below (IoT, blockchain, quantum) |
| 4B1 | Security concepts, frameworks and standards | 4.2; Knowledge topics; Added below |
| 4B2 | Security and risk awareness training | 4.8 |
| 4B3 | Data privacy and data protection | 4.5 |
| Task 24 | Facilitate tabletop exercises | 4.4 |

# Added below: the remaining outline subtopics

These fill every row marked “Added below” in the outline check.

## Domain 1

### 1A6 Organisational asset management

- Lifecycle: plan → acquire → deploy → maintain → retire and dispose securely.
- A complete, current inventory is the foundation: hardware, software, data, cloud services, OT devices. Each has an owner, a classification, a value and a location.
- Asset value drives impact ratings and the level of protection.
- Unknown assets (shadow IT, unauthorised devices, end-of-life software) are high risk: you can’t protect what you don’t know you have.
- Exam: FIRST step to protect assets → a complete inventory with owners. GREATEST risk of an incomplete inventory → unprotected, unpatched, unmonitored assets. Who values and classifies → the asset owner.

**1A5 Business processes and resilience (governance angle):** identify critical processes and their dependencies on people, IT, suppliers and facilities. Senior management owns continuity; governance makes sure plans exist, are tested and are maintained. Detail sits in 2.6 and 4.4.

## Domain 2

### 2B1 Risk assessment concepts and standards

| Term | Meaning |
|---|---|
| Asset | Anything of value to the enterprise |
| Threat | Potential cause of harm |
| Vulnerability | Weakness a threat can exploit |
| Likelihood | Probability or frequency of the event |
| Impact | Consequence to objectives if it happens |
| Risk | Combination of likelihood and impact (ISACA writes “risk”, singular) |
| Exposure | Extent to which an asset is open to the risk |
| Risk velocity | How fast the impact arrives after the event |
| Risk factor | Condition that changes likelihood or impact |

Standards: ISO 31000, ISO/IEC 27005, NIST SP 800-30, COSO ERM. Assessments must be consistent, repeatable and documented, and repeated both periodically and when something significant changes.

## Domain 3

### 3B3 Control testing methodologies

- Evidence strength, weakest to strongest: inquiry → observation → inspection → re-performance. Inquiry alone is never enough.
- **Test of design:** would the control work as designed? **Test of operating effectiveness:** did it work consistently across the period?
- Sampling: statistical or judgemental; the sample must cover the whole period.
- Automated testing and continuous controls monitoring suit high-volume controls.
- **Control self-assessment:** owners test their own controls. It builds ownership but needs independent validation.
- Technical tests: vulnerability scans and authorised, scoped penetration tests.
- Exam: BEST evidence a control operates → re-performance or independent testing.

### 3C2 Data collection, aggregation, analysis and validation

- Data quality: accurate, complete, timely, consistent, relevant.
- Validate the source and reconcile to it before anything is reported.
- Aggregate on one taxonomy and one rating scale so risk combines across units.
- Aggregation reveals concentrations, but watch for double counting and severe risks averaged away.
- Exam: MOST important before reporting aggregated risk → validate data integrity.

### 3C4 Risk and control monitoring techniques

- Continuous automated monitoring (SIEM, controls monitoring tools), KRI tracking, periodic reviews, control self-assessment, incident and audit trends, threat intelligence.
- Prefer automated, continuous monitoring for high-risk, high-volume areas.

- Monitoring (first and second line) and audit (third line) run in parallel.

**3C5 Risk and control reporting techniques**

| Technique | What it shows | Best audience |
|---|---|---|
| Heatmap | Risks plotted by likelihood and impact; concentrations at a glance | Board, executives |
| Scorecard | Metrics against targets (often a balanced scorecard) | Management |
| Dashboard | Near-real-time KRIs and KCIs with red/amber/green status and trends | Risk and control owners, management |
| Risk register report | Full detail per risk | Owners, second line |
| Trend analysis | Direction of travel over time | Board, risk committee |

Reports are tailored to the audience, in business language, timely, accurate and actionable. The board gets the profile against appetite, trends and emerging risk.

**3C6 Emerging risk**

- Horizon scanning: technology change, regulation, threat landscape, geopolitics, supply chain.
- Record emerging risk on a watchlist with an owner even when data is thin, and reassess it as it matures.
- Report early to senior management; don’t wait for certainty. Use scenario analysis when data is limited.

## Domain 4

**4A1 Technology principles**

- Components: infrastructure (servers, network, storage), platforms, applications, data, end-user devices, and operational technology (OT) on the shop floor.
- Principles: standardisation, interoperability, scalability, availability, security by design, least functionality.
- Technical debt and unsupported (end-of-life) systems are risk.
- OT differs from IT: availability and safety come first and patching is harder, so segment OT networks.

**4A2 Technology roadmaps and enterprise architecture**

- EA moves from current state to target state; the gap between them becomes the roadmap. Frameworks include TOGAF and Zachman.
- A roadmap is the planned evolution of technology aligned with strategy: what is adopted, upgraded and retired, and when.
- Risk angle: obsolescence, end of support, technical debt, dependencies, misalignment.
- Exam: PRIMARY benefit of EA → IT aligned with business, with less duplication and complexity. Risk of no roadmap → unsupported technology and uncoordinated investment.

**4A3 DevOps**

- Development and operations combined, with CI/CD pipelines releasing frequently and automatically.
- Risk: segregation of duties between development and production weakens; changes can bypass the CAB.
- Controls: automated testing and security scanning in the pipeline (DevSecOps), approval gates, restricted pipeline access, automatic deployment logs. These compensate for weaker segregation.

**4A6 Portfolio and project management (Agile)**

- **Portfolio:** selects and prioritises programmes and projects by strategic value, risk and resources, and stops low-value ones.
- **Programme:** related projects delivering a shared benefit. **Project:** temporary, with a defined scope.
- The business case justifies benefits, costs and risks; it is reviewed at stage gates and kept so benefits can be checked afterwards.
- The sponsor is accountable; the steering committee directs; the PMO standardises.
- Project risks: scope creep, overruns, unclear requirements, benefits not realised.
- **Agile:** short sprints, a product owner and a backlog. Risk: documentation and controls get skipped. Control: put security and control requirements into user stories and the “definition of done”.
- A post-implementation review checks that benefits were realised.

**4A8 Emerging technologies beyond AI**

- **IoT:** many unmanaged devices with weak default credentials that are hard to patch. Inventory and segment them.
- **Blockchain:** strong integrity through immutability. Risks: key loss, smart-contract flaws, privacy (records can’t be deleted).
- **Quantum computing:** a future threat to today’s public-key cryptography (“harvest now, decrypt later”). Inventory cryptography and build crypto-agility.
- **Robotic process automation:** bot credentials and uncontrolled scripts need the same access control as people.

**4B1 Security concepts**

- CIA triad: confidentiality, integrity, availability, plus authenticity and non-repudiation.
- Access sequence: identification → authentication → authorisation → accountability (logging).
- Authentication factors: something you know, have or are. MFA means two *different* factor types.
- Principles: least privilege, need to know, segregation of duties, defence in depth.
- **Zero trust:** never trust by network location; verify every request, every time.
- Privileged access management covers admin accounts: vaulting, just-in-time access and session logging.

# Distinctions that decide close answers

Most hard questions turn on one of these pairs. Know each in one line.

| Pair | The difference |
|---|---|
| Capacity · appetite · tolerance · profile | Cliff edge · where the board chooses to walk · measurable wobble allowed · where you are today |
| Tolerance vs acceptance | Tolerance is a limit set in advance; acceptance is a decision on one risk. Inside tolerance the owner accepts; outside it needs senior management, documented, with an expiry (like a concession on an out-of-tolerance part) |
| KRI vs tolerance | The KRI is the needle; tolerance is the red zone on the dial; amber is the warning before the limit |
| KRI · KPI · KCI | Risk exposure (early warning) · process performance · control effectiveness |
| Who accepts risk | Risk owner within appetite · senior management above it · board sets appetite and oversees · practitioner never |
| Risk owner vs control owner | Risk owner decides about the risk; control owner keeps the control designed, operating and routinely monitored (and may delegate the doing to an operator) |
| First-line monitoring vs audit | Owner monitors routinely; internal audit tests independently; both run in parallel |
| Data owner vs custodian | Owner classifies and decides access and retention; custodian (IT) implements |
| Controller vs processor | Controller decides purpose and means; processor acts on its behalf |
| Governance vs management (COBIT) | Board evaluates, directs, monitors; management plans, builds, runs, monitors |
| Risk vs issue | Risk might happen; an issue has happened |
| Exception vs exemption | Exception is temporary, approved, expires; exemption is a justified longer-term scope-out |
| Compliance | The law decides whether; risk decides how and when. Laws can’t be excepted internally; contracts only by the counterparty; internal policy through the exception process |
| Tailoring vs SoA | Tailoring adapts the whole framework (process and controls); the SoA is ISO 27001’s record of which controls apply and why |
| Incident vs problem | Incident management restores service; problem management removes the root cause |
| IDS vs IPS | IDS detects (detective); IPS blocks (preventive) |
| Control sequence | Deterrent → preventive → detective → corrective → recovery; compensating substitutes; directive instructs |
| Verb to level | Set direction or approve = board and senior management · manage and execute = mid-level managers · perform = frontline · respond = incident team · assure = internal audit |

**The escalation test:** escalate only when risk exceeds appetite **and** your authority, or a material gap stays unaddressed after the owner has seen the evidence. If a standard route exists (support the owner, get alternative assurance, find the reason for a delay), it’s not an escalation question.

# More exam rules

Further rules worth knowing, grouped by area.

**Governance**

- Several jurisdictions apply → adopt the most stringent baseline, with legal counsel input.
- A stale compliance register = unknown legal exposure; refresh it.
- An enterprise framework already exists → align IT risk to it. Mandate a new one only if none exists.
- Pressure to keep a material risk out of a board report → resist; report it.

**Risk assessment**

- Threat sources: adversarial, accidental, structural, environmental.
- Refresh threat models when the environment or threat landscape changes.
- Supporting systems inherit the criticality of the most critical process that depends on them.
- A documented zero-tolerance exposure needs a risk scenario, even while a control is planned.
- Recovery timing: **RPO** = data loss allowed; **RTO** = time to restore systems; **work recovery time** = time to verify data and resume business; **MTD** = RTO + work recovery time.

**Risk response and controls**

- Risk acceptance is a documented, economic decision: cost of the control versus asset value and potential loss. Any other reason is wrong.
- Segregation of duties isn't possible → compensating control, never acceptance.
- Inconsistent manual performance → automate.
- Shared accounts → repudiation is the primary risk.
- System control verification → managing alerts beats log reviews.
- Authorised exceptions keep bypassing a control → improve senior management risk awareness.
- Expired exceptions → fresh risk assessment and re-approval; exceptions are never back-dated.
- Disabled control → re-enable, find the root cause, review the exposure window; "no incidents" never excuses skipping that review.
- Recurring issues → investigate the systemic root cause.
- Monitoring and audit run in parallel; good monitoring never reduces audit.
- BCP test shows the RTO can't be met → escalate to the board as a material risk before any cost-benefit analysis.

## How exam questions try to trick you

The qualifier decides the answer. When two options both look right, reread it.

| Qualifier | What it rewards | Typical trap |
|---|---|---|
| FIRST | The earliest correct step | A good action that comes later (treat before assess, escalate before analyse) |
| BEST / MOST effective | The most complete answer | A good option that does only part of the job |
| MOST important | What everything else depends on | A secondary factor (cost, ease, compliance) |
| MOST likely | The probable cause or outcome | A possible but less probable, more dramatic option |
| PRIMARY | The main purpose | A real by-product or secondary benefit |
| GREATEST concern or risk | The biggest business exposure | The process lapse or paperwork behind it |

**Other tricks:** an option that repeats the stem’s wording; one word that moves ownership to the wrong role; an option from a different classification scheme; a technical answer to a business question; and the qualifier’s object (“efficient”, “objectivity”, “three lines model”) narrowing what counts as best.

# Common traps and exam-day routine

Most marks are lost through the same handful of habits. Check every answer against this list before you commit.

| Trap | Correct instinct |
|---|---|
| Escalating routine issues to the board or CRO | Escalate only when risk is beyond appetite **and** beyond authority, or a material gap is unaddressed |
| Practitioner choosing the treatment (transfer, accept) | Present the analysis; the owner decides |
| Paperwork or process over exposure | “Concern” and “GREATEST risk” mean the actual impact |
| Technical fix before root cause | Assess first, then pick controls |
| Point-in-time assurance for gradual risk | Continuous KRIs |
| Splitting the difference | Evidence decides (BIA data, impact figures) |
| The drastic or absolute option | The proportionate fix using existing tools |
| Mechanism over purpose | PRIMARY purpose = better risk-informed decisions |
| Picking the specialist because the topic matches (DPO for privacy, CISO for security) | The owner is whoever made the decision and benefits; specialists advise |
| Picking the most senior role | Match the stem’s verb to the level that does it |
| An option that repeats the stem’s wording | Usually a distractor; pick the option that says how |
| Long options that look alike | Find the one word that moves ownership or accountability |
| An option from a different classification scheme | Answer within the scheme the other options use |
| Signatures, reading or discipline to make a policy work | Education that changes behaviour |
| Asset cost, data value or wages as “impact” | Losses to the affected business units |
| Gap analysis before a reference exists | Pick the standard first, then measure the gap |

**The escalation test:** escalate when the risk exceeds appetite and your authority, or a known material gap is being ignored. If a standard route exists (alternative assurance, an owner to support, a reason to find), it is not an escalation question.

**Answering routine for every question**

1. Read the last line first. Mark the qualifier (FIRST, BEST, MOST, GREATEST, PRIMARY) and the actor.
2. Check the actor’s job: the practitioner analyses and recommends, the owner decides, the board sets appetite and oversees.
3. Eliminate absolutes, wrong-actor answers and technical fixes where a governance step is missing.
4. Choose between the last two: which protects objectives, respects the owner and comes first?

**Pacing:** about 35–40 questions an hour. Flag and move on; never leave a blank, as wrong answers cost nothing.